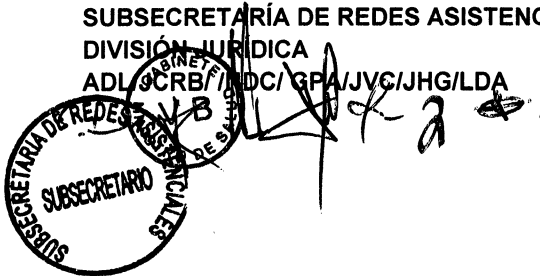


GABINETE MINISTRO
SUBSECRETARÍA DE REDES ASISTENCIALES
DIVISIÓN JURÍDICA
ADL/9CRB/11DC/GPA/JVC/JHG/LDA



**APRUEBA INSTRUCTIVO DE SEGURIDAD
DE LA INFORMACIÓN Y
CIBERSEGURIDAD PARA EL SECTOR
SALUD.**

RESOLUCIÓN EXENTA N° 785,

SANTIAGO, - 3 NOV 2021

VISTOS:

Lo dispuesto o dispuesto en la Ley N°21.289 de Presupuestos del Sector Público para el año 2021; en el D.F.L. N° 1 de 2005, del Ministerio de Salud, que fija el texto refundido, coordinado y sistematizado del Decreto Ley N°2.763 de 1979 y de las leyes Nos 18.933 y 18.469; el D.F.L. N°1/19.653 de 2000, del Ministerio Secretaría General de la Presidencia, que fija el texto refundido, coordinado y sistematizado de la ley N°18.575, Orgánica Constitucional de Bases Generales de la Administración del Estado; Resolución Exenta N°889 de 26 de noviembre de año 2019, que "Aprueba Política General de Seguridad de la Información para la Subsecretaría de Salud Pública y la Subsecretaría de Redes Asistenciales y deja sin efecto resolución que indica", el memorándum A22 N° 110, de 12 de abril de 2021, y N°126 de 27 de abril de 2021, ambos del Jefe del Departamento Tecnologías de la Información y Comunicaciones, además de recado interno de fecha 06 de mayo de 2021 del encargado de seguridad Minsal, en que se solicita la elaboración del acto administrativo pertinente; y la Resolución N° 18, de 2020, de la Contraloría General de la República sobre exención del trámite de toma de razón; y

CONSIDERANDO:

1.- Que, las Tecnologías de la Información y las Comunicaciones son insumos esenciales en los distintos procesos institucionales en el sector de la salud. En este contexto, la ley 19.880 ha previsto que los procedimientos administrativos podrán constar en expedientes físicos o electrónicos, lo que llevará a que su tramitación pueda desarrollarse a través de medios computacionales.

2.- Que, conforme al artículo 6 de la ley 19.799, sobre documentos electrónicos, firma electrónica y servicios de certificación de dicha firma, “los órganos del Estado podrán ejecutar o realizar actos, celebrar contratos y expedir cualquier documento, dentro de su ámbito de competencia, suscribiéndolos por medio de firma electrónica”.

3.- Que, por Decreto N°83, de 2005 del Ministerio Secretaría General de la Presidencia, se estableció la norma técnica sobre seguridad de la información de los documentos electrónicos que se generen, intercambien, transporten y almacenen en o entre los diferentes organismos de la Administración del Estado y en las relaciones de éstos con los particulares, cuando éstas tengan lugar utilizando técnicas y medios electrónicos.

4.- Que conforme al artículo 5 letra p) del Decreto N° 83 antes citado, se define Política de Seguridad como el *“conjunto de normas o buenas prácticas, declaradas y aplicadas por una organización, cuyo objetivo es disminuir el nivel de riesgo en la realización de un conjunto de actividades de interés, o bien garantizar la realización periódica y sistemática de este conjunto”*. Conforme el artículo 11 de este mismo instrumento, la Política deberá fijar las *“directrices generales que orienten la materia de seguridad dentro de cada institución, que refleje claramente el compromiso, apoyo e interés en el fomento y desarrollo de una cultura de seguridad institucional”*.

5.- Que el Ministerio de Salud, la “Política General de Seguridad de la Información para la Subsecretaría de Salud Pública y la Subsecretaría de Redes Asistenciales” ha sido aprobada por Resolución Exenta N° 889, de 26 de noviembre de 2019, y en el contexto de esta política, se hace necesario aprobar los instrumentos complementarios, que permitan desarrollar los procedimientos asociados a la concreción de las políticas.

6.- Que, al Ministerio de Salud le compete ejercer la función que le corresponde al Estado de garantizar el libre e igualitario acceso a las acciones de promoción, protección y recuperación de la salud, y de rehabilitación de la persona enferma; así como coordinar, controlar y, cuando corresponda, ejecutar tales acciones. Asimismo, el Ministerio de Salud ejerce la rectoría del sector salud, comprendiendo la dirección y orientación de todas las actividades del Estado y los particulares relativas a la provisión de acciones de Salud.

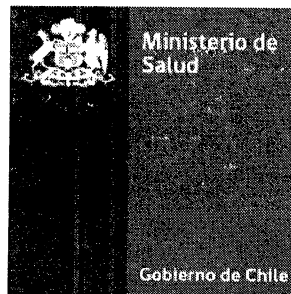
Que, en vistas a lo considerado se hace necesario dictar la siguiente,

RESOLUCIÓN:

1º APRUÉBASE, el Instructivo de seguridad de la información y ciberseguridad para el sector salud, cuyo texto íntegro es el siguiente:

Versión 1.3

Fecha: Agosto 2021



INSTRUCTIVO DE SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD PARA EL SECTOR SALUD

Ministerio de Salud
Departamento Tecnologías de la
Información y Comunicaciones

Contenido

1. PROPÓSITO / OBJETIVO	6
2. ALCANCE O AMBITO DE APLICACIÓN	6
3. MARCO NORMATIVO DE SEGURIDAD DE LA INFORMACIÓN	6
4. MARCO DE DEFINICIONES	7
5. ELEMENTOS CLAVES PARA LA GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN	8
5.1 Compromiso del Nivel Directivo	8
5.2 Implementación	9
5.3 Política de Seguridad de la información	9
5.4 Comité de Seguridad	9
5.5 Encargado de Seguridad	9
5.6 Encargado de Ciberseguridad	9
5.7 Usuarios finales	9
5.8 Gestión de la Seguridad de la Información de forma transversal en la Institución	10
6. DIRECTRICES PARA LA GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN	11
6.1 Decálogo de principios de Seguridad de la Información	11
6.2 Lineamientos en la Identificación de requisitos para la Seguridad de la Información	12
6.3 Lineamientos para la Gestión de Riesgo	12
6.4 Lineamientos para las Operaciones Seguras	13
6.5 Lineamientos de Ciberseguridad	15
6.6 Lineamientos para la Gestión de Incidentes de Seguridad y Ciberseguridad	17
6.6.1 Gestión de Incidentes	17
6.6.2 Obligación de reportar Incidentes	18
6.6.3 Niveles de peligrosidad	18
6.6.4 Niveles de impacto	20
6.6.5 Niveles de impacto	21
6.6.6 Oportunidad de los reportes	22
6.6.7 Canales de comunicación	22
6.6.8 Tratamiento de los reportes	23
6.6.9 Resolución de ciberincidentes	23
6.7 Lineamiento de Seguridad para el desarrollo de software seguro.	23
6.8 Lineamiento sobre Tratamiento de datos sensibles para uso en nube y contratos relacionados Marco normativo de la nube.	24
6.8.1 Seguridad en Nube	26
6.9 Estructura Documental	27
6.10 Lineamientos de Gestión para la Mejora Continua	28
6.11 Lineamientos en Medición del Nivel de cumplimiento y Niveles de Madurez	28
7. CONTROLES DE SEGURIDAD MÍNIMOS A IMPLEMENTAR	30



INSTRUCTIVO DE SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD PARA EL SECTOR SALUD

MINISTERIO DE SALUD

Versión: 1.3

Página 5 de 52

7.1	Dominio Nº 5. Políticas de Seguridad de la Información	30
7.2	Dominio Nº 6 Organización de la seguridad de la información	30
7.3	Dominio Nº 7 Seguridad de recursos humanos	32
7.4	Dominio Nº 8 Administración de activos	32
7.5	Dominio Nº 9 Control de acceso	34
7.6	Dominio Nº 10 Criptografía	36
7.7	Dominio Nº 11 Seguridad física y ambiental	36
7.8	Dominio Nº 12 Seguridad de las operaciones	38
7.9	Dominio Nº 13 Seguridad en las comunicaciones	40
7.10	Dominio Nº 14 Adquisición, desarrollo y mantenimiento de sistemas	40
7.11	Dominio Nº 15 Relaciones con los proveedores	42
7.12	Dominio Nº 16 Administración de incidentes de seguridad de la información	43
7.13	Dominio Nº 17 Aspectos de la seguridad de la información de la administración de la continuidad del Negocio	43
7.14	Dominio Nº 18 Cumplimiento	44
8.	APROBACIÓN Y CONTROL DE VERSIONES	45
9.-	ANEXO 1: PANORAMA REGULATORIO CIBERSEGURIDAD NACIONAL, LEYES RELATIVAS A LA CIBERSEGURIDAD	46
10.-	ANEXO 2: DOCUMENTOS Y RECURSOS DE REFERENCIA	50
11.-	ANEXO 3: EJEMPLO DE ESTRUCTURA DE POLÍTICAS Y PROCEDIMIENTOS	51
	DISTRIBUCIÓN:	52

1. PROPÓSITO / OBJETIVO

El presente instructivo tiene como objetivo, entregar lineamientos para la implementación de una línea base de Seguridad de la información y ciberseguridad, en las Secretarías Regionales Ministeriales de Salud, Servicios de Salud y Establecimientos relacionados, que permitan resguardar la confidencialidad, integridad y disponibilidad de la información en las actividades realizadas para la gestión de servicios, teniendo como referencia la Norma Chilena NCh-ISO 27001. Of 2013, Marco de Seguridad del NIST Controles SP 800-53 y líneas de base de control SP 800-53B.

Entregar contenidos normativos de alto nivel para su revisión, análisis de factibilidad y adopción en las propias políticas institucionales de sus Sistemas de Seguridad de la Información, de cada Servicio.

2. ALCANCE O AMBITO DE APLICACIÓN

El presente instructivo debería ser considerado como recomendación y propuesta para las Instituciones y Servicios del Sector. Es aplicable sobre todo tipo de información, considerando todo medio de soporte y presentación, como son la voz y medios digitales, ya sean magnético, óptico, electrónico o fotográfico.

3. MARCO NORMATIVO DE SEGURIDAD DE LA INFORMACIÓN

Son documentos relacionados y parte del marco normativo sectorial de Seguridad de la Información: El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.

- Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad:
 - Leyes, Decretos de Ciberseguridad y Norma ISO vigentes, publicados en el sitio web CSIRT <https://www.csirt.gob.cl>

- **ANEXO N°1** Panorama Regulatorio Ciberseguridad Nacional, Departamento CSIRT área jurídica División de Redes y Seguridad de la Información Subsecretaría del Interior.
 - Leyes y Decretos
 - Normativas

- Políticas y procedimientos de Seguridad del Ministerio de Salud, disponibles en la Intranet Ministerial:

- <http://isalud.minsal.cl/ministerio/dgstic/SGSI/Paginas/default.aspx>

- En especial se deberá dar cumplimiento a los siguientes cuerpos normativos Ministerial:

- **Normativa del sector salud:** DFL N° 1, de 24 de abril de 2006, Ministerio de Salud, que fija el texto refundido, coordinado y sistematizado del Decreto Ley N° 2.763, de 1979 y de las leyes N° 18.933 y 18.469; DFL N° 725, Ministerio de Salud, Código Sanitario; la Ley N° 20.584, referida a Deberes y Derechos que tienen las Personas en relación con acciones vinculadas a su Atención de Salud; Decreto N° 41, de 24 de julio de 2012, del Ministerio de Salud, Reglamento de Ficha Clínica; Decreto N° 31 de 15 de junio de 2012, del Ministerio de Salud, Reglamento sobre entrega de información y expresión de consentimiento informado en las atenciones de salud; la ley 20.724, de 2014, que modifica el Código Sanitario en materia de regulación de medicamentos; ley 20.850, de 2016, que crea un sistema de protección financiera para diagnósticos y tratamientos de alto costo y rinde homenaje póstumo a don Luis Ricarte Soto Gallegos; ley 19.966, de 2004, que establece un régimen de garantías de salud; ley 19.650, que perfecciona normas del área de la salud; ley 20.120 de 22 de septiembre de 2006, sobre la investigación científica en el ser humano, su genoma, y prohíbe la clonación humana y demás normativa del área de la salud.

- **En materia de protección de datos personales:** el art. 19 N° 4 de la Constitución Política de la República y la ley de protección de datos personales N° 19.628 y su normativa complementaria; la ley 20.575 sobre el principio de finalidad en el tratamiento de datos personales, la ley 19.496 de derechos y deberes de los consumidores.
- **Leyes de aplicación general:** DFL N° 29, que fija el texto refundido, coordinado y sistematizado de la ley 18.834, sobre estatuto administrativo; Ley 19.880 de bases de los procedimientos administrativos; Ley 19.886 de bases sobre contratos administrativos de suministro y prestación de servicios; Ley NÚM. 21.180, de transformación digital del Estado; ley 20.285 de transparencia y acceso a la información pública; Ley 19.886 de compras públicas.

4. MARCO DE DEFINICIONES

Para los efectos de la aplicación de este documento, así como la gestión vinculada a ella, los términos que a continuación se señalan tendrán el significado que se indica:

- a. **Apetito de riesgo:** es la cantidad de riesgo que una organización está dispuesta a asumir para alcanzar sus objetivos estratégicos.
- b. **Autenticación:** Proceso utilizado en los mecanismos de control de acceso con el objetivo de verificar la identidad de un usuario, dispositivo o sistema mediante la comprobación de credenciales de acceso.
- c. **Ciberataque:** Cualquier incidente cibernético, provocado deliberadamente y que afecte a un sistema informático.
- d. **Ciberespacio:** Dominio global y dinámico dentro del entorno de la información que corresponde al ambiente compuesto por las infraestructuras tecnológicas, los componentes lógicos de la información, los datos (almacenados, procesados o transmitidos) que abarcan los dominios físico, virtual y cognitivo y las interacciones sociales que se verifican en su interior. Las infraestructuras tecnológicas corresponden a los equipos materiales empleados para la transmisión de las comunicaciones, tales como enlaces, enrutadores, conmutadores, estaciones, sistemas radiantes, nodos, conductores, entre otros. Los componentes lógicos de la información, en tanto, son los diferentes softwares que permiten el funcionamiento, administración y uso de la red.
- e. **Ciberincidente:** Todo evento que comprometa la disponibilidad, autenticidad, integridad o confidencialidad de los sistemas o datos informáticos almacenados, transmitidos o procesados, o los servicios correspondientes ofrecidos por dichos sistemas y su infraestructura, que puedan afectar al normal funcionamiento de los mismos.
- f. **Ciberseguridad:** Conjunto de acciones destinadas a posibles para la prevención, mitigación, investigación y manejo de las amenazas e incidentes sobre los activos de información, datos y servicios, así como para la reducción de los efectos de los mismos y del daño causado antes, durante y después de su ocurrencia.
- g. **Confidencialidad:** Principio de seguridad que requiere que los datos deberían únicamente ser accedidos por el personal autorizado a tal efecto.
- h. **Continuidad de servicios:** Adoptar las medidas que permitan proveer un nivel mínimo de servicio, entendiendo por esto las prestaciones propias del seguro, reduciendo el riesgo de eventos que puedan crear una interrupción o inestabilidad en las operaciones de la entidad hasta niveles aceptables y planificando la recuperación de los servicios de las tecnologías de la información (TI).
- i. **Disponibilidad:** Capacidad de ser accesible y estar listo para su uso a demanda de una entidad autorizada.
- j. **Equipo de Respuesta ante Incidentes de Seguridad Informática, en adelante (CSIRT):** Centros conformados por especialistas multidisciplinarios capacitados para prevenir, detectar, gestionar y responder a incidentes informáticos, en forma rápida y efectiva, y que actúan según

procedimientos y políticas predefinidas, coadyuvando asimismo a mitigar los efectos de ataques de ciberseguridad. Para efectos de este documento, corresponde al Departamento dependiente de la División de Redes y Seguridad Informática del Ministerio del Interior y Seguridad Pública creado mediante la resolución N°5.006, de 20 de agosto de 2019, del mencionado Ministerio.

- k. **Gestión de incidentes:** Procedimientos para la detección, análisis, manejo, contención y resolución de un incidente de ciberseguridad y responder ante ésta.
- l. **Incidente:** Evento inesperado o no deseado con consecuencias en detrimento de la seguridad de las redes, equipos y sistemas de información.
- m. **Integridad:** Principio de seguridad que certifica que los datos y elementos de configuración sólo son modificados por personal y actividades autorizadas. La Integridad considera todas las posibles causas de modificación, incluyendo fallos software y hardware, eventos medioambientales e intervención humana.
- n. **Nube privada:** La infraestructura de la nube se aprovisiona para uso exclusivo de una única organización que comprende múltiples consumidores (por ejemplo, unidades de negocio). Puede ser propiedad, administrado y operado por la organización, un tercero o una combinación de ellos, y puede existir dentro o fuera de las instalaciones de la organización.
- o. **Nube pública:** La infraestructura y los recursos lógicos que forman parte del entorno se encuentran disponibles para el público en general a través de Internet. Suele ser propiedad de un Prestador de Servicios que gestiona la infraestructura y el servicio o servicios que se ofrecen.
- p. **Protección de los activos de información:** Adoptar las medidas que resguarden la seguridad física de los dispositivos, así como los accesos a éstos. Se entenderá por infraestructura crítica las instalaciones, redes, servicios y equipos físicos y de tecnología de la información cuya afectación, degradación, denegación, interrupción o destrucción pueden tener una repercusión importante en los trabajadores protegidos, pensionados, empresas adherentes o afiliadas y en las prestaciones preventivas, médicas y económicas que debe brindar el seguro.
- q. **Resiliencia:** Capacidad de los sistemas, equipos o redes para seguir operando pese a estar sometidos a un incidente o ciberataque, aunque sea en un estado degradado, debilitado o segmentado. Así como, incluye la capacidad de restaurar con presteza sus funciones esenciales después de un incidente o ataque de modo de recuperarse con presteza de una interrupción, por lo general con un efecto reconocible mínimo.
- r. **Riesgo de Ciberseguridad:** Toda circunstancia o hecho razonablemente identificable que tenga un posible efecto adverso en la seguridad de las redes, equipos y sistemas de información. Se puede cuantificar como la probabilidad de materialización de una de las amenazas antes mencionadas que produzca un impacto en términos de operatividad, o de integridad, confidencialidad o disponibilidad de datos.
- s. **Seguridad de la información:** Conjunto de medidas preventivas y reactivas de los organismos administradores y sus respectivos sistemas tecnológicos, que tienen por objeto resguardar y proteger la información, asegurando la confidencialidad, integridad, autenticidad y disponibilidad de los datos, continuidad de servicios y protección de activos de información.
- t. **Vulnerabilidad o brecha informática:** Debilidad de un activo o control que puede ser explotado por una o más amenazas informáticas.

5. ELEMENTOS CLAVES PARA LA GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN

5.1 Compromiso del Nivel Directivo

El compromiso es necesario para la ejecución de la visión de seguridad de la información. Esto también incluye el involucramiento y una estructura que maneje y revise regularmente el estado general del Sistema de Seguridad de la Información y provea direccionamiento cuando sea necesario.

Debería estar conformado a lo menos por:

- Encargado de Seguridad de la Información o Ciberseguridad de la Institución.
- Jefe de Tecnologías de la Información.
- Jefe de Recursos Humanos.
- Encargado Planta Física y Seguridad.
- Encargado de Calidad.
- Encargado de Riesgos.
- Asesor Jurídico (Abogado).
- Jefes de Áreas de Negocio o Encargados de Procesos.

5.2 Implementación

Los productos por sí solos no resuelven los problemas de seguridad de la información. Se debería implementar un proceso continuo, que involucre aspectos tecnológicos además de procesos y personas, para lo cual se requieren soluciones integrales. Las políticas relativas a ciberseguridad y seguridad de la información, así como de sus respectivos planes de gestión de riesgo deben ser actualizados al menos una vez al año debido al vertiginoso avance de las tecnologías.

5.3 Política de Seguridad de la información

Se necesita una política de seguridad de la información que refleje las expectativas de la organización con el fin de proveer administración, dirección y soporte a los valores establecidos.

5.4 Comité de Seguridad

Sus integrantes son responsables de definir y establecer los lineamientos generales de seguridad, publicar y aprobar las políticas, normas y demás definiciones en lo que respecta a seguridad de la información. También son los responsables de evaluar técnicamente las propuestas, participar en procesos de evaluación de riesgos, recomendar planes de acción y atender contingencias.

5.5 Encargado de Seguridad

Es el encargado de velar por el marco normativo establecido y los requerimientos necesarios para garantizar la protección de la información y los recursos informáticos de la Institución.

5.6 Encargado de Ciberseguridad¹

Responsable de la seguridad informática de su servicio, de velar por el cumplimiento de las normas de seguridad de la información.

Debe evaluar riesgos en materias de ciberseguridad, análisis del estado actual de vulnerabilidades de su servicio, medidas adoptadas para enfrentarlos y plan de acción de corto plazo para mitigar dichos riesgos.

5.7 Usuarios finales

Todo colaborador, con independencia de su régimen contractual, es responsable de la información que manipula; así como del correcto uso de los recursos tecnológicos que le hayan sido asignados para apoyar tareas relacionadas con la Seguridad de la Información y con sus obligaciones laborales.

La implementación de la Gestión de la Seguridad de la Información debe incluir a todos los usuarios finales que participan en los procesos de la Institución. Se debe entender como usuarios finales a todos quienes tienen la responsabilidad de acatar las políticas y normativas definidas, independiente que además tengan otro rol nominado en este ámbito.

Debe considerar:

- A todos los funcionarios (planta, contrata, reemplazos y suplencia),
- Personal a honorarios,

¹ Instructivo Presidencial N°8/2018

- Terceros (proveedores, compra de servicios, tratamiento por encargo, servicios externalizados, etc.),

Los requerimientos de seguridad hacia terceros y personal a honorarios deben estar considerados en los TDR: Términos de referencia del acuerdo base del servicio contratado.

Para mejorar la cultura organizacional, se considera primordial la difusión, capacitación y concientización de estos lineamientos y todo el marco normativo de Seguridad de la Información para todos los Usuarios finales.

Las políticas y procedimientos de Seguridad de cada Servicio deben ser conocidas y respetadas, como parte de los deberes de cada funcionario, honorarios o terceros. Su no cumplimiento debería ser considerado como una falta grave contra la protección de los intereses y los activos de cada Servicio, en los términos de las normas que rigen el estatuto del personal.

5.8 Gestión de la Seguridad de la Información de forma transversal en la Institución

La Seguridad de la Información debe ser gestionada de forma transversal, y no ser de exclusiva responsabilidad del Departamento TIC. Para esto se debe abordar en los siguientes procesos y sus responsables en cada Servicio:

- a) **Seguridad de los recursos humanos:** Se establece la necesidad de informar y educar a todos los empleados y terceros relacionados con la empresa sobre lo que se espera de ellos en materias de seguridad de la información.
- b) **Seguridad física y ambiental:** Identificación de los riesgos asociados al acceso físico a las instalaciones y arquitectura tecnológica de la institución por parte de funcionarios y terceros (partners de negocio, proveedores, otros), con el objeto de prevenir el acceso no autorizado, daño e interferencia a las instalaciones de la institución y a la información.
- c) **Gestión de las comunicaciones y las operaciones:** Generar y definir por una parte procedimientos y responsabilidades operacionales con el objeto de asegurar la correcta operación de los medios de procesamiento de la información y por otra implementar políticas de respaldo y restauración de los datos en forma oportuna.
- d) **Control de acceso:** Se debe asegurar que el acceso del usuario es debidamente autorizado y evitar el acceso no autorizado a los sistemas de información, estableciendo procedimientos formales de control en la asignación de los derechos de acceso a los sistemas de información. Todas las etapas en el ciclo de vida del acceso del usuario deben estar contempladas en estos procedimientos, esto es, desde el registro inicial de nuevos usuarios hasta la baja de estos porque ya no requieren acceso a los sistemas de información. Poner especial atención en la asignación de derechos de acceso con privilegios que puedan permitir a los usuarios superar los controles del sistema. Implementar una política de escritorio y pantalla limpios de manera que por una parte reducir el riesgo de acceso no autorizado y por otra, robo o daño a los papeles u otros medios de almacenamiento de la información.
- e) **Adquisición, desarrollo y mantenimiento de los sistemas de información:** En los sistemas de información están incluidos sistemas operativos, infraestructura, aplicaciones para el negocio, servicios y aplicaciones desarrolladas internamente por la institución. Se deben identificar y acordar todos los requerimientos de seguridad antes del desarrollo y/o implementación de los sistemas y deben ser justificados, acordados y documentados como parte de las formalidades para un sistema de información. Las instituciones que desarrollan el software internamente o bien, contraten el desarrollo a una empresa externa, deben garantizar que la seguridad sea parte de los sistemas de información desarrollados e incluir los requerimientos de seguridad desde la etapa de las especificaciones del software y en todo el ciclo de vida del programa.
- f) **Gestión de Incidentes en la Seguridad de la Información y Ciberseguridad:** Se debe asegurar que las debilidades, problemas y eventos de seguridad de la información asociados a los sistemas de información sean comunicados en forma oportuna de modo de permitir tomar

acciones correctivas a tiempo. Debe establecerse un procedimiento formal tanto para informar cualquier evento de seguridad de la información junto con la respuesta al incidente, como un procedimiento de escalamiento, comunicando la acción que se tomará al momento de recibir un informe de un evento de seguridad de la información. Procedimientos que deben ser debidamente difundidos de manera que sean de conocimiento de todos los funcionarios. Para tales efectos se deberán considerar lo indicado en la Guía de Notificación de Incidentes para Organismos de la Administración Pública que tiene por objeto establecer un estándar común para la notificación de incidentes de Ciberseguridad, en base a la obligación derivada del IP N° 8, por parte de los organismos de la Administración Pública, disponible en www.csirt.gob.cl.

- g) **Gestión de la continuidad del negocio:** Se deberán tomar medidas de prevención y mitigación para prevenir y reducir al mínimo los efectos de los ciberincidentes, que afecten la seguridad de las redes, equipos y sistemas utilizados para la prestación de los servicios, con el objeto de garantizar su continuidad operativa, bajo una perspectiva de continuidad negocio y de Recuperación de la Plataforma Tecnológica. En todos los casos, se deberá diseñar, implementar, practicar y evaluar un plan de respuesta que otorgue adecuada cobertura a sus redes, equipos y sistemas en conformidad con estándares internacionales o nacionales, de amplia aplicación y, a su vez, desde el punto de vista de los clientes, garantizar la integridad, disponibilidad y confidencialidad de la información.
- h) **Cumplimiento:** Se deben generar procedimientos rutinarios de auditoría con el objeto de evitar los incumplimientos de cualquier ley, estatuto, regulación u obligación contractual legal y de cualquier requisito de seguridad a los cuales puede estar sujeto el diseño, operación, uso y gestión de los sistemas de información, los que deberán establecer plazos periódicos que permitan ejecutar un control efectivo sobre normativa vigente en esta materia.

6. DIRECTRICES PARA LA GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN

6.1 Decálogo de principios de Seguridad de la Información

Se recomienda mantener una versión acotada, resumida, de muy alto nivel y de fácil comprensión de los más relevantes lineamientos que declare la institución respecto a la Seguridad de la Información.

A nivel del Sector Salud, Minsal declara su compromiso de:

- Promover la Información como un activo vital del quehacer en el sector salud.
- Proteger la privacidad y confidencialidad de toda información sensible o de carácter personal, independiente de su formato, medio de soporte y almacenamiento.
- Preservar la integridad de los datos, ya que de su exactitud, actualización y veracidad pueden llegar a depender una vida.
- Asegurar que la información crítica estará disponible en tiempo y forma sólo para quienes estén debidamente autorizados para tener acceso a ella.
- Establecer un modelo de gestión de Riesgos para la Seguridad de la Información; que permita determinar el tipo y naturaleza de controles necesarios para la mitigación de los riesgos identificados como relevantes.
- Cumplir con el marco normativo establecido para la seguridad de la información del Sector Salud e Institucional, mediante la gestión de los controles definidos.
- Mantener respaldos seguros que permitan el resguardo de la información gestionada por el sector Salud, que permitan prevenir eventuales pérdidas o daño de ella. Asimismo, incluir la definición del responsable y la frecuencia de las pruebas de restauración de la información para los sistemas críticos.
- Habilitar equipos y sistemas de identificación, análisis, notificación, respuesta, resguardo de registros y aprendizaje frente a debilidades e incidentes de Seguridad de la Información, permitiendo su mitigación y evitando su recurrencia.

- Desarrollar programas de educación para todo el personal del Sector Salud, con el objetivo de mejorar la comprensión y competencias del marco normativo de seguridad de la información y los relativos a la ciberseguridad².
- Apoyar la construcción de una plataforma de intercambio recíproco de experiencias y aprendizaje en todos los aspectos de la seguridad de la información del sector Salud.

6.2 Lineamientos en la Identificación de requisitos para la Seguridad de la Información

Las Instituciones del Sector Salud deberían identificar y periódicamente analizar las fuentes que generan sus requisitos de seguridad de la información, donde destacan:

- Un modelo y una metodología formal de gestión de riesgos, consistente con los cambios institucionales y lineamientos del Sector Salud.
- Los requisitos legales, normativos y contractuales que aplican al Sector de Salud, sobre todo los que generan nuevos requerimientos de protección de Confidencialidad, Integridad, Disponibilidad, Trazabilidad y gestión en general de la protección de información sensible.
- Los eventos adversos propios o provenientes de amenazas externas que hayan ocurrido recientemente, dejando en evidencia debilidades en sus actuales sistemas de protección o modelos de control en seguridad de la información.
- Las amenazas del ciberespacio, que deben ser monitoreadas y analizadas para determinar su potencial riesgo.
- Los propios lineamientos institucionales y procesos de innovación, por su relación con apertura de nuevos frentes o factores de riesgo.

6.3 Lineamientos para la Gestión de Riesgo

- La gestión de los riesgos de las tecnologías de la información implica identificar, analizar, evaluar, tratar, monitorear y comunicar el impacto de los riesgos de las tecnologías de la información sobre los procesos de los organismos administradores.
- Una vez que se identifiquen los riesgos y se determine el apetito y la tolerancia de riesgo, se recomienda especificar la estrategia de gestión de riesgos, asignando un responsable por cada riesgo identificado y, dependiendo de su importancia e impacto, definir cómo tratar el riesgo, es decir, evitar, mitigar, transferir o aceptar dicho riesgo.
- Por otra parte, se recomienda que los criterios de tratamiento del riesgo estén especificados y formalizados, y que éstos sean revisados anualmente por la alta administración y el órgano directivo de la institución, dejándose registro de dicha actividad.
- La identificación y formalización de los riesgos de tecnologías de la información y actividades que contemplan el uso, transporte o almacenamiento de activos de información que impiden cumplir con el objetivo de mantener la confiabilidad, integridad y disponibilidad de los datos, continuidad de servicios y protección de dichos activos de información se realizará en la correspondiente matriz de riesgo y controles, identificando claramente los riesgos que los organismos administradores asocian a los riesgos de seguridad de la información.
- De igual forma, se recomienda que los organismos administradores adopten las medidas adecuadas para prevenir y reducir al mínimo los efectos de los ciberincidentes que afecten la seguridad de sus redes, equipos y sistemas, con el objeto de garantizar su continuidad operativa, así como la continuidad de la seguridad de la información. En todos los casos, se podrá diseñar, implementar, practicar y evaluar un plan de respuesta que otorgue adecuada cobertura a sus redes, equipos y sistemas, en conformidad con estándares internacionales o nacionales, de amplia aplicación y, a su vez, desde el punto de vista de los grupos de interés, garantizar la integridad, disponibilidad y confidencialidad de la información.

² El CSIRT de gobierno cuenta con una gran cantidad de material de concientización y que se encuentra disponible para su uso y difusión. Campañas publicadas por : <https://www.csirt.gob.cl/recomendaciones/>

6.4 Lineamientos para las Operaciones Seguras

Se deberán implementar mecanismos de gestión y monitoreo que protejan la infraestructura de TI de amenazas físicas y tecnológicas, maximizar la efectividad de la operación de las plataformas tecnológicas, velando por un procesamiento correcto y seguro de la información en las instituciones del Sector Salud.

- La institución debe identificar los lineamientos mínimos necesarios para proteger la información y las dependencias TI de procesamiento de información, estableciendo sus propias políticas y controles normativos al respecto. Para ello debe analizar al menos el siguiente conjunto de lineamientos mínimos, y convertirlos en procesos de gestión de mejora continua para cada temática:
 - **Gestión de cambios en sistemas y plataformas relevantes:**
 - Se deben controlar los cambios a la organización, procesos de negocio, instalaciones de procesamiento de información y los sistemas que afecten la seguridad de la información.
 - Todo cambio debe ser identificado, asignado los roles y responsables, cuantificado, comunicado a los involucrados y documentado; para ser gestionado adecuadamente lo que implica su planificación, evaluación de impactos, pruebas del cambio.
 - Se debe configurar procedimientos de realización del cambio, de vuelta atrás en caso de falla, de aprobación y verificación de los requerimientos.
 - Se deben implementar procedimientos para controlar la instalación del software en los sistemas operacionales.
 - Asimismo, se deben establecer restricciones para los cambios e instalación de software en las estaciones de trabajo. Cambios relevantes deben someterse a procesos de pruebas previas.
 - **Gestión de la capacidad de las redes, plataformas y sistemas:**
 - Se debe identificar, según criticidad para el negocio, las capacidades necesarias de las principales redes, plataformas y sistemas.
 - Mediante monitoreo y supervisión, se debe evaluar el uso de los recursos, para hacer proyecciones de los futuros requisitos de capacidad, con el fin de dar continuidad operacional a los sistemas.
 - Se deben integrar a la proyección futura, los nuevos requisitos de la institución y las tendencias actuales y proyectadas de procesamiento.
 - Este control debe evolucionar a gestionar también la capacidad de los recursos no TI; como recursos humanos, oficinas e instalaciones.
 - **Gestión de amenazas en los entornos pre-productivos:**
 - Se deben controlar los accesos y cambios en los entornos pre-productivos como en explotación, para ello se deben separar los ambientes de desarrollo y prueba del operacional.
 - Lo anterior significa separar entornos pre-productivos del operacional:
 - Definir y documentar las reglas de transferencia de software desde un estado de desarrollo al operacional;
 - Ejecutar en distintos sistemas o procesadores y en distintos dominios y directorios.
 - Probar cambios en entorno de pruebas antes de aplicarlos a los sistemas en producción.
 - El software o utilitarios de desarrollo deben estar aislados del entorno productivo.
 - Se deben usar cuentas y perfiles diferenciados.
 - Se deben mantener datos especiales de prueba y no usar los de producción.

○ **Gestión de códigos maliciosos:**

- Se deben definir, implementar, comunicar, concientizar y mejorar en el tiempo, un conjunto complementario de controles de detección, prevención y recuperación contra códigos maliciosos.
- Lo anterior significa:
 - Prohibir el uso de software no autorizado, controlar su cumplimiento.
 - Evitar o detectar el uso de sitios web desconocidos o que se sospecha son maliciosos.
 - Efectuar monitoreo de integridad del software y del contenido de los datos de los sistemas críticos.
 - Gestionar formalmente un software anti-malware, migrando a la detección y control de amenazas avanzadas.
 - Mantener planes de recuperación contra ataques de malware.
 - Mantenerse informado de las nuevas amenazas aparecidas.

○ **Gestión de respaldos de información digital:**

- Se deben hacer copias de respaldo de la información, software y sistemas relevantes para la institución, con período de retención acorde a las necesidades institucionales y efectuando pruebas de recuperación y verificación de consistencia de dicha información y del software y sistemas necesarios.
- Se deben formalizar como estándar de respaldo de Información, los requerimientos de tipo de respaldo, periodicidad, tiempo de retención y nivel de protección necesarios.
- Todo el proceso de respaldo se debe revisar y auditar contra lo establecido en esta política.
- Especial atención se debe aplicar al respaldo, retención y recuperación de registros vitales de la institución.
- En el caso de los sistemas y servicios críticos, las disposiciones de respaldo deberían abarcar la información de todos los sistemas, aplicaciones y datos necesarios para recuperar al sistema completo en el caso de un desastre.
- Se debería contar además con instalaciones de respaldo adecuadas para garantizar que toda la información relevante, el software esencial y los sistemas corporativos se puedan recuperar después de un desastre y ante una falla de los medios.
- Para los efectos de disponibilizar ambientes de contingencia, se podrá evaluar la nube privada como medio para disponer de infraestructura de algunos eventos de continuidad, puesto que se pueden conservar ambientes a menor escala que los ambientes de producción con el objetivo de minimizar las interrupciones, y sólo activarlos cuando sea necesario, sin incurrir en el costo periódico de mantenerlos todos los tiempos disponibles.
- Con ello, se puede aprovechar la diversa disponibilidad geográfica de los servicios para efectos de continuidad o distribución de respaldos, considerando la disposición del uso de nube privada cuenta con datacenters con presencia nacional.

○ **Gestión de los registros de eventos de seguridad:**

- Se deben identificar, planificar su extracción, generar, mantener, proteger adecuadamente y revisar con regularidad los respaldos de registros de eventos de las actividades relevantes del usuario, excepciones, fallas y eventos de seguridad de la información.
 - Especial cuidado de protección y resguardo se deben establecer sobre los registros del administrador y el operador de las plataformas y sistemas críticos.

○ **Sincronización de relojes en plataformas TI:**

- Los relojes de todos los sistemas de procesamiento de información pertinente dentro de la organización o dominio de seguridad deben estar sincronizados con una sola fuente horaria de referencia, con el fin de lograr trazabilidad y permitir instancias de correlación de registros (LOGs) frente a incidentes o efectuar análisis forense posterior.
- **Gestión de vulnerabilidades y funcionales:**
 - Se deberá robustecer la seguridad y mejorar los mecanismos de protección en los productos de software desarrollados para Minsal, con el objetivo de minimizar los riesgos tecnológicos que pudiera presentar el paso producción y a ser expuestos a Internet.
 - Como parte de sus actividades preventivas, previo paso a producción de los aplicativos y antes de ser expuestos a Internet, las instituciones deberán aplicar técnicas de hacking ético o análisis de seguridad, para detectar vulnerabilidades o fallas de seguridad en el sistema y, de esta manera, adoptar todas las medidas necesarias que posibiliten prevenir incidentes de seguridad, en función del alcance y periodicidad definidos por el organismo administrador.
 - De la misma forma, se deberán implementar actividades que permitan el aseguramiento de calidad sobre dicho software, con el fin de velar porque las definiciones funcionales y niveles de servicio esperadas por el organismo hayan sido adecuadamente implementadas en el software desarrollado.
 - Respecto a los activos de la organización que se encuentran accesibles a los proveedores, se deberá acordar con éstos un nivel de seguridad de la información y prestación de servicios conforme a la importancia de dichos activos.
- **Controles de auditoría de sistemas de información:**
 - Los requisitos y las actividades de auditoría que involucran verificaciones sobre sistemas operacionales se deben planificar y acordar cuidadosamente para minimizar el riesgo de interrupciones en los procesos del negocio.
 - Junto con ello se deberán incorporar en el plan anual de auditoría interna, la revisión sobre la consistencia de los datos reportados a los sistemas de información de la institución.
- **Trabajo a distancia:**
 - En lo relativo a las instrucciones de ciberseguridad y seguridad de la información para trabajo a distancia, se deberán considerar las recomendaciones descritas en la guía técnica del CSIRT del Ministerio del Interior en el contexto de la pandemia “Protocolo de Trabajo Remoto”³, para establecer condiciones de conexión remota segura con los trabajadores que tengan la obligación o necesidad de cumplir con sus funciones a distancia, estén cumpliendo labores en comisión de servicio o por condiciones de salud personal o general que les impidan presentarse en sus puestos de trabajos.

6.5 Lineamientos de Ciberseguridad

La ciberseguridad implica la seguridad en los equipos y redes, en el software y en el hardware que busca proteger la información digital en los sistemas interconectados, está comprendida dentro de la seguridad de la información y tiene que ver con todas las medidas de seguridad que se deberían tomar en estos aspectos para evitar ataques y pérdida de datos. En este aspecto, se deberían considerar las siguientes recomendaciones:

- Aumentar la capacidad de vigilancia de las redes y los sistemas, para ello se debe contar con el equipo de profesionales de tecnologías existentes en cada establecimiento o Servicio de Salud que apoye esta tarea.

³ Protocolo de Trabajo Remoto: <https://www.csirt.gob.cl/media/2020/03/Protocolo-de-seguridad.pdf>

- Activar las auditorías de los sistemas de acceso perimetral. Deberá conocer quién se conecta, a qué hora y desde qué dirección IP. Monitorizar de forma proactiva y continua la seguridad de la infraestructura de los Establecimientos.
- Implementar medidas de seguridad en la red de comunicaciones firewalls de nueva generación, routers y switches actualizados, etc.
- Monitorización y correlación de eventos. Uso de herramientas capaces de monitorizar el tráfico de red, usuarios remotos, contraseñas de administración, etc.
- Implementar medidas de prevención de pérdida de datos, orientadas también a la monitorización y control.
- Realizar configuraciones de seguridad en todos los componentes de la red Institucional. Se deberían incluir los dispositivos móviles y portátiles.
- Deberá considerar el uso de productos, equipos y servicios confiables y certificados. Redes y sistemas acreditados.
- Reforzar la disponibilidad de su infraestructura crítica, implementando redundancia.
- Adecuación progresiva de los permisos de usuario, servicios en la “nube” y la utilización de dispositivos y equipos propiedad del usuario (BYOD).
- Resguardar su conexión a la Red Ministerial a través VPN (Virtual Private Network) ya que permite establecer una conexión remota segura (encriptada) a la red institucional.
- Implementar doble factor de autenticación a los usuarios que realicen Atención Remota en sus dispositivos. (Ej: la primera una contraseña y la segunda un SMS o código numérico, entre otros)
- Revisar los planes de copia de seguridad (Backup), y realización de tests para recuperación de servicios completos.
- Diseñar un plan de contingencia y continuidad de negocio en caso de algún incidente grave de Ciberseguridad.
- Utilizar equipos con los resguardos de seguridad correspondientes: antivirus reconocido y actualizado, sistema operativo licenciado y con sus parches al día, y aplicaciones licenciadas y actualizadas, especialmente aquellos expuestos a Internet y los utilizados en Atención Remota.
- Evaluar el incremento del ancho de banda para garantizar las conexiones concurrentes de Atención Remota.
- Automatizar e incrementar el intercambio de información. Reciprocidad con Equipo de Respuesta ante Incidentes de Seguridad Informática CSIRT del Ministerio del Interior soc-csirt@interior.gob.cl y Equipo de Seguridad del Ministerio de Salud seguridadtic@minsal.cl, en concordancia con lo indicado en Guía de Notificación de Incidentes del CSIRT.
- Los cargos directivos deberían ser los primeros en aceptar que existen riesgos, promover las políticas de seguridad y establecer un compromiso con la ciberseguridad.
- Junto con lo anterior, se deberá priorizar la formación y la sensibilización de usuarios en esta materia, para todos y cada uno de los niveles de la organización (dirección, gestión e implantación). Los que deben ser conscientes de los riesgos y actuar en consecuencia.
- Atenerse a las buenas prácticas y adecuación a los distintos estándares, establecidos por el Ministerio de Salud a través de las Políticas y Procedimientos publicados en la Intranet Institucional.

Se recomienda establecer lineamientos mínimos para la determinación de las medidas de gestión de la ciberseguridad como lo son los conceptos de:

- a) Seguridad física y ciberseguridad de los sistemas e instalaciones;
- b) Resiliencia de la red, equipos y sistemas;
- c) Gestión del riesgo propio de la actividad;
- d) Gestión de incidentes;
- e) Gestión de la continuidad de los servicios;
- f) Monitoreo permanente de los sistemas;

- g) Actividades de supervisión, auditoría y prueba;
- h) Conocimiento de las alertas de ciberincidentes a nivel nacional e internacional;
- i) Actualización constante de protocolos y sistemas de seguridad;
- j) Seguridad en los componentes tecnológicos de los equipos para los servicios entregados, que garanticen adecuadamente la integridad, confidencialidad y disponibilidad de las transmisiones e información;
- k) Calificación, capacitación y seguridad del personal que opera los componentes tecnológicos;
- l) Los principios y estándares internacionalmente aceptados en materia de Ciberseguridad, tales como, y sin ser exclusivos, las recomendaciones de la OCDE incluidas en el “Digital Security Risk Management for Economic and Social Prosperity” (2015) y “Recommendation on Digital Security of Critical Activities” (2019).

6.6 Lineamientos para la Gestión de Incidentes de Seguridad y Ciberseguridad⁴

Para tales efectos, como criterio de referencia se deberán considerar lo indicado en la Guía de Notificación de Incidentes para Organismos de la Administración Pública que tiene por objeto establecer un estándar común para la notificación de incidentes de Ciberseguridad, en base a la obligación derivada del IP N° 8, por parte de los organismos de la Administración Pública, disponible en www.csirt.gob.cl, las que indican:

6.6.1 Gestión de Incidentes

- Gestionar los incidentes de seguridad de la información o ciberseguridad. Para ello deben crear una bitácora que contenga la descripción de cada una de las actividades desarrolladas en la gestión de estos.
- Designar dentro de la Institución los responsables de gestionar, comunicar y dar respuesta a los incidentes de seguridad, liderado por el responsable de seguridad en la institución la ciberseguridad, así como del diseño, mantención, seguimiento y notificación de los riesgos de seguridad de la información y ciberseguridad, considerando controles de segregación de deberes y áreas de responsabilidad para reducir las oportunidades de modificación o uso indebido no autorizado o no intencional de los activos de la organización, incluyendo las nuevas formas de trabajo a distancia o teletrabajo.
- Es recomendable que el organismo administrador cuente con un equipo de respuesta para la adecuada gestión de la ciberseguridad, con el objeto de identificar los riesgos de afectación de los servicios por causa de ciberincidentes, verificar el cumplimiento eficaz de los respectivos planes de gestión y reportar los ciberincidentes.
- Asimismo, las instituciones debiesen establecer planes de gestión de riesgos de ciberseguridad, formulados de acuerdo a estándares y directrices que guarden la debida coherencia con las características de las redes, equipos y sistemas críticos.
- Se recomienda que los planes de gestión de riesgo sean actualizados y sometidos a aprobación de la dirección institucional y conocidos por el nivel directivo, junto con señalar el estado de los riesgos de ciberseguridad, indicadores claves, principales ciberincidentes y planes de acción de mejoras. Junto a lo anterior, se recomienda que los planes de gestión de riesgo incluyan medidas para la protección de los datos personales y sensibles, en cumplimiento con lo establecido en la Ley N° 19.628.

⁴ Todo evento que comprometa la disponibilidad, autenticidad, integridad o confidencialidad de los sistemas o datos informáticos almacenados, transmitidos o procesados, o los servicios correspondientes ofrecidos por los sistemas de telecomunicaciones y su infraestructura, que puedan afectar al normal funcionamiento de los mismos.

6.6.2 Obligación de reportar Incidentes

- Las instituciones deberán reportar al CSIRT de Gobierno soc-csirt@interior.gob.cl⁵ y al Equipo de Seguridad Ministerial seguridadtic@minsal.cl, todos los ciberincidentes que detecten en sus redes, equipos y sistemas y que alcancen los niveles de peligrosidad e impacto establecidos en este instructivo. Junto a ello, la referida notificación deberá hacerse en la forma y los tiempos que se señalan. Como criterio de referencia para el reporte de un ciberincidente se utilizará el nivel de peligrosidad e impacto que se le asigne conforme a las tablas indicadas.
- Los incidentes catalogados por el responsable de seguridad de la institución, que afecten disponibilidad, autenticidad, integridad o confidencialidad de los sistemas, deben ser comunicados Equipo de Seguridad Ministerial, con el fin de poder llevar una estadística de los incidentes, conocer las tipologías de estos y gestionar el conocimiento en beneficio de todas las instituciones de la Red.
- El responsable de seguridad de la institución deberá, coordinar la respuesta a incidentes y según el análisis e investigación de los incidentes y teniendo en cuenta la causa raíz, realizar los respectivos planes de mejoramiento, para lo cual el responsable de seguridad de la entidad supervisará y hará seguimiento a su cumplimiento.

6.6.3 Niveles de peligrosidad

- El nivel de peligrosidad determina la potencial amenaza que supondría la materialización de un incidente en las redes, equipos y sistemas del organismo, así como para la calidad o continuidad en el otorgamiento del servicio.
- Conforme a sus características, las amenazas son clasificadas con los siguientes niveles de peligrosidad: Crítico, Muy Alto, Alto, Medio y Bajo. El nivel asignado se determinará según se indica en la tabla a continuación:

Nivel de Peligrosidad		
Nivel	Clasificación	Tipo de incidente
Crítico	Amenaza Avanzada Persistente	APT: Ataques dirigidos contra organizaciones concretas, sustentados en mecanismos muy sofisticados de ocultación, anonimato y persistencia. Esta amenaza habitualmente emplea técnicas de ingeniería social para conseguir sus objetivos junto con el uso de procedimientos de ataque conocidos o genuinos.
Muy alto	Código dañino	Ataques consistentes en la distribución de programas computacionales destinados a afecta indebidamente el funcionamiento de un sistema de la información o los datos contenidos en él, a través del sistema de información. Distribución de malware. Ej: recurso de una organización empleada para distribuir malware. Configuración de malware. Ej: ataque de webinjects para troyano.

⁵ Instructivo Gabinete Presidencial N°8 del 23 de octubre de 2018 del Ministerio del Interior.

	Intrusión	Ataques consistentes en accesos indebidos al sistema de información, ya sea quebrantando los sistemas de seguridad o mediante la utilización indebida de sistemas de acceso legítimos. Acceso no autorizado: Ej: acceso no autorizado a un sistema informático con el fin de conocer sus datos internos, apoderarse de ellos o utilizar sus recursos, acceso no autorizado a Centro de Proceso de Datos. Abuso de claves: Ej. Abuso de claves para acceder a partes del sistema o datos respecto de los cuales no se es usuario legítimo. Sabotaje: Ej: destrucción, inutilización, de un sistema de tratamiento de información, la destrucción, alteración de datos contenidos en un sistema de tratamiento de información, cortes de cableados de equipos o incendios provocados.
	Disponibilidad del servicio	Ataque informático que afecta la continuidad operacional de los sistemas de información, provocando interrupciones del servicio. Interrupciones. Ej: ataque informático.
	Contenido abusivo	Pornografía infantil, contenido sexual o violento inadecuado.
Alto	Código Dañino	Material que represente de manera visual contenido relacionado con pornografía infantil, apología de la violencia, etc. Ataque consistente en la introducción al sistema de la institución código dañino. Sistema infectado: Ej: Sistema, computadora o teléfono móvil infectado con un rootkit. Servidor C&C (Mando y Control): Ej: Conexión con servidor de Mando y Control (C&C) mediante malware o sistemas infectados.
	Intrusión	Compromiso de aplicaciones: Ej: Compromiso de una aplicación mediante la explotación de vulnerabilidades de software, como podría serlo una inyección de SQL. Compromiso de cuentas con privilegios: Ej: Compromiso de un sistema en el que el atacante ha adquirido privilegios
	Intento de Intrusión	Ataque desconocido: Ej: Ataque empleando exploit desconocido
	Disponibilidad del servicio	DoS (Denegación de servicio): Ej: envío de peticiones a una aplicación web que provoca la interrupción ralentización en la prestación del servicio. DDoS (Denegación distribuida de servicio): Ej: inundación de paquetes SYN, ataques de reflexión y amplificación utilizando servicios basados en UDP.
	Compromiso de la información	Acceso no autorizado a información: Ej: robo de credenciales de acceso mediante interceptación de tráfico o mediante el acceso a documentos físicos. Modificación no autorizada de información: Ej: modificación por un atacante empleando credenciales sustraídas de un sistema o aplicación o encriptado de datos mediante ransomware Sabotaje a los datos: Ej: pérdida de datos por ataque al sistema o robo físico de dispositivos de almacenamiento.
Medio	Fraude	Ingeniería social: Ataque consistente en engaños a los usuarios o a terceros para la entrega indebida de información relativa a claves de acceso.

		Ej: Phishing
	Contenido abusivo	Discurso de odio Ej: ciberacoso, racismo, amenazas a una persona o dirigidas contra colectivos
	Obtención de información	Ingeniería social Ej: mentiras, trucos, sobornos, amenazas Explotación de vulnerabilidades conocidas: Ej: desbordamiento de buffer, puertas traseras, cross site scripting (XSS).
	Intrusión	Intento de acceso con vulneración de credenciales: Ej: intentos de ruptura de contraseñas, ataque por fuerza bruta. Compromiso de cuentas sin privilegios
	Disponibilidad del servicio	Mala configuración: Ej: Servidor DNS con el KSK de la zona raíz de DNSSEC obsoleto. Uso no autorizado de recursos: Ej: uso de correo electrónico para participar en estafas piramidales.
	Fraude	Derechos de autor: Ej: uso, instalación, distribución de software sin la correspondiente licencia. Suplantación: Ej: suplantación de una entidad por otra para obtener beneficios ilegítimos
	Explotación de Vulnerabilidad	Criptografía débil: Ej: servidores web susceptibles de ataques POODLE/FREAK. Amplificador DDoS: Ej: DNS openresolvers o Servidores NTP con monitorización monlist. Servicios con acceso potencial no deseado: Ej: Telnet, RDP o VNC. Revelación de información: Ej: SNMP o Redis. Sistema vulnerable: Ej: mala configuración de proxy en cliente (WPAD), versiones desfasadas de sistema.
Bajo	Contenido abusivo	Spam Escaneo de redes Ej: peticiones DNS, ICMP, SMTP, escaneo de puertos.
	Obtención de información	Análisis de paquetes (sniffing):
	Otros	Otros: Todo aquel incidente que no tenga cabida en ninguna categoría anterior.

6.6.4 Niveles de impacto

Los criterios empleados para la determinación del nivel de impacto asociado a un ciberincidente atienden los parámetros que se indican a continuación, sin un orden de prelación o importancia predeterminado:

- Tipología de la información o sistemas afectados.
- Grado de afectación a las instalaciones.
- Posible interrupción en la prestación del servicio normal
- Tiempo y costos propios y ajenos hasta la recuperación del normal funcionamiento de las instalaciones y equipos.
- Pérdidas económicas.
- Cantidad de unidades operativas o de negocio afectadas

- Daños reputacionales asociados

Los posibles niveles de impacto de un ciberincidente son Crítico, Muy alto, Alto, Medio, Bajo o Sin Impacto. El nivel de impacto correspondiente se asignará usando como referencia la siguiente tabla:

Nivel	Descripción
Crítico	Afecta a la seguridad ciudadana con potencial peligro para la vida de las personas.
	Afecta a sistemas clasificados como confidenciales o que contengan información calificada como datos sensibles de acuerdo con la ley.
	Afecta a más del 50% de los procesos que soportan los sistemas de la institución.
	Interrupción en la prestación del servicio igual o superior a 12 horas o superior al 40% de los usuarios.
	Afecta a más del 50% de sus instalaciones a nivel nacional.
	Daños reputacionales de difícil reparación, con eco mediático afectando a la reputación de terceros.
Muy alto	Afecta a la seguridad ciudadana con potencial peligro para bienes materiales.
	Afecta la vida privada y/o la honra de la persona y su familia, y asimismo, la protección de sus datos personales.
	Afecta a más del 40% de los procesos que soportan los sistemas de la institución.
	Interrupción en la prestación del servicio igual o superior a 8 horas o superior al 30% de los usuarios.
	Afecta a más del 40% de sus instalaciones a nivel nacional.
	Daños reputacionales, con eco mediático afectando a la reputación de terceros.
Alto	Afecta a más del 30% de los procesos que soportan los sistemas de la institución
	Interrupción en la prestación del servicio igual o superior a 6 horas o superior al 20% de los usuarios.
	Afecta a más del 30% de sus instalaciones a nivel nacional.
	Daños reputacionales, con eco mediático afectando a la reputación de terceros.
Medio	Afecta a más del 20% de los procesos que soportan los sistemas de la institución.
	Interrupción en la prestación del servicio igual o superior a 4 horas y superior al 10% de los usuarios.
	Afecta a más del 20% de sus instalaciones a nivel nacional.
	Daños reputacionales, con eco mediático que no afecta la reputación de terceros.
Bajo	Afecta al 10% o más, de los sistemas de la institución.
	Interrupción en la prestación del servicio igual o superior a 2 horas y superior al 5% de los usuarios.
	Afecta al 10% o más, de sus instalaciones a nivel nacional.
	Daños reputacionales sin eco mediático.
Sin impacto	No hay ningún impacto apreciable.

6.6.5 Niveles de impacto

Se deberá reportar en tiempo y forma toda aquella información relativa al ciberincidente que sea exigible. Sin embargo, en el reporte inicial solamente deberá proporcionar la información que tenga en su conocimiento en ese momento, debiendo completarla en los reportes que envíe con posterioridad.

Los reportes de ciberincidentes deberán contener, a lo menos, los siguientes campos de información:

- a. Resumen ejecutivo del ciberincidente.
- b. Identificación de la institución e instalación u oficina afectada.
- c. Encargado de ciberseguridad en funciones.
- d. Fecha y hora precisas de ocurrencia del ciberincidente, si se conociere.

- e. Fecha y hora precisas de detección del ciberincidente.
- f. Descripción detallada de lo sucedido.
- g. Recursos tecnológicos afectados.
- h. Origen o causa identificable del ciberincidente, si se conociere.
- i. Taxonomía, clasificación o tipo de ciberincidente.
- j. Nivel de peligrosidad.
- k. Nivel de impacto.
- l. Indicadores de compromiso: indicadores de compromiso de nivel IP, indicadores de compromiso de nivel de dominios y subdominios, indicadores de compromiso de correos, indicadores de compromiso a nivel MD5, entre otros similares.
- m. Plan de acción y medidas de resolución y mitigación.
- n. Afectados actuales y potenciales.
- o. Medios necesarios para la resolución calculados en horas de trabajo necesarias.
- p. Impacto económico estimado, si procede y es conocido.
- q. Cantidad de unidades operativas o de negocio afectadas, si se conociere.
- r. Daños reputacionales, aun cuando sean eventuales.
- s. Las bitácoras generadas de forma automática por los sistemas, si corresponde.
- t. Antecedentes que se adjuntan, si procede.
- u. Clasificación de confidencialidad TLP asignada al incidente:

6.6.6 Oportunidad de los reportes

Los reportes consideran tres etapas: un reporte inicial, reportes intermedios y un reporte final.

El reporte inicial, obligatorio, es una comunicación consistente en poner en conocimiento y alertar de la existencia de un ciberincidente. Los reportes intermedios actualizan los datos disponibles en ese momento en relación con el ciberincidente comunicado. Se efectuarán tantos reportes intermedios como se consideren necesarios a partir de la hora en que se generó el reporte inicial. Con todo, deberá informarse, haya o no novedades, con la frecuencia indicada en la tabla que se presenta a continuación, salvo que se haya efectuado el reporte final del ciberincidente en ese mismo período.

El reporte final amplía y confirma los datos definitivos en relación con el ciberincidente reportado a partir del día en que se generó el reporte inicial

Nivel de peligrosidad o impacto	Reporte inicial	Reporte intermedio	Reporte final
Crítico	1 hora	3/ 6/ 12/ 24/ 48 horas	Máximo 10 días corridos
Muy alto	1 hora	6/ 12/ 24/ 48/ 72 horas	Máximo 20 días corridos
Alto	1 hora	24/ 48/ 72 horas	Máximo 30 días corridos

Los plazos que se consignan se computan desde el momento que se toma conocimiento del incidente o de sus efectos, ya sea sobre el sistema o los datos.

6.6.7 Canales de comunicación

Los organismos públicos deberán reportar a la casilla de correo electrónico soc@interior.gob.cl del CSIRT de Gobierno y al Ministerio de Salud a través del Equipo de Seguridad Ministerial seguridadtic@minsal.cl o Mesa de Servicios mesadeservicios@minsal.cl , en tiempo y forma todos los ciberincidentes que registren en sus redes, equipos y sistemas de información y que estén obligados a notificar por superar los umbrales de impacto o peligrosidad.

En caso de que por efectos del incidente la notificación no se pueda llevar a cabo por el correo electrónico precedente, se podrá realizar a través del sistema <https://www.csirt.gob.cl> y como tercera opción de manera telefónica al número de emergencias Cibernéticas 1510.

La obligación de reportar se entenderá formalmente cumplida con el envío del reporte al CSIRT de Gobierno a través de los mecanismos dispuestos para ello.

6.6.8 Tratamiento de los reportes

Los reportes de ciberincidentes serán tratados como documentación confidencial. En particular, en aquellos datos que pudiera exponer antecedentes técnicos propios de la institución, que pongan en riesgo la ciberseguridad de esta, así como la información de usuarios en conformidad a la legislación sobre protección de la vida privada.

6.6.9 Resolución de ciberincidentes

Una vez detectado un ciberincidente que afecte a una red, equipo o sistema utilizado para el funcionamiento y/o la prestación de servicios, el organismo deberá efectuar de manera oportuna todas las gestiones que sean necesarias para su resolución y restaurar la normal provisión de los servicios afectados, con arreglo a su plan de gestión de riesgos y, en todos los casos, dando primera prioridad a aquellas medidas que permitan evitar o, en su defecto, minimizar el impacto a los usuarios y la continuidad del negocio.

6.7 Lineamiento de Seguridad para el desarrollo de software seguro.

Se deberían integrar la seguridad de la información, dentro del ciclo de vida del desarrollo, adquisición o mantención del software, para todos los sistemas de información, aplicaciones web y móviles, así como cualquier otro sistema que almacene, transmita o presente información, desde las etapas iniciales como el diseño y el levantamiento de requerimientos, hasta las pruebas de seguridad una vez el software se encuentre en producción, teniendo en cuenta los riesgos asociados a cada sistema de información. Para todo lo relacionado con las aplicaciones, se debe configurar y usar algún proyecto OWASP para la revisión en búsqueda de vulnerabilidades en la aplicación. Esto, para corregir lo que sea necesario antes de entregar la aplicación.

Se deberían implementar mecanismos de autenticación seguros, como el uso de contraseñas de características fuertes⁶ y calidad adecuadas. También se deben implementar mecanismos de limitación de intentos de inicio de sesión, ya sea ralentizando los intentos de inicio de sesión, bloqueando la IP de origen de las pruebas fallidas o bloqueando las cuentas después de un número predeterminado de intentos fallidos. Esta estrategia no debe bloquear permanentemente las cuentas, puesto que esto podría causar una denegación de servicio a los usuarios legítimos. En el caso de que los ataques de fuerza bruta sean un problema, es recomendado implementar múltiples factores de autenticación para

⁶ Una contraseña segura consta de al menos diez (10) caracteres (y mientras más caracteres, más fuerte es la contraseña), que son una combinación de letras, números, símbolos y el uso de mayúsculas y minúsculas. Ésta no debe contener palabras que se pueden encontrar en un diccionario o partes del nombre del usuario. Se incluyen las recomendaciones del CSIRT relativa a la creación de contraseñas seguras. Link con recomendaciones: <https://www.csirt.gob.cl/recomendaciones/ciberconsejos-para-crear-contrasenas-seguras/>

verificar al usuario. Uso de autenticación criptográfica a través de módulos de hardware criptográfico seguro, en conjunto con algún mecanismo de autenticación adicional (password, biometría, otros).

Los datos sensibles o críticos deben estar identificados para poder implementar las protecciones que requieran de forma correcta. Las comunicaciones de los componentes que transporten información de los usuarios entre sistemas deberían siempre estar protegidas mediante TLS, y los sistemas correctamente configurados para seleccionar el cifrado más fuerte disponible.

Se debe evitar, cuando sea posible, el almacenamiento de datos sensibles por parte de la aplicación. En caso de que no se pueda evitar almacenar datos sensibles, éstos deben ser protegidos mediante encriptación, para prevenir la modificación o acceso no autorizado.

Se deberían implementar sistemas de acceso seguro a los datos, debiendo cada usuario acceder sólo a aquellos respecto de los cuales tiene permisos habilitados a través de sus perfiles de usuario o las condiciones legales de acceso, de acuerdo con sus competencias, tratándose de información sensible, como la información de salud de pacientes.

Establecer mecanismos de comunicación segura de datos, cualquiera que sea el medio o técnica utilizada para su transferencia o comunicación desde el origen hasta el usuario requirente, utilizando mecanismos de seguridad consecuentes a un nivel alto de protección consistente con el medio en el cual se transferirá o comunicará la información.

Cualquiera que sea el medio o técnica de transferencia o comunicación de los datos, se deberán establecer plazos máximos de almacenamiento y métodos para la destrucción de los mismos, mantener registro auditable (log) con la identificación del usuario que accede a los datos (requirente), la descripción del contenido al que accede, el motivo o propósito del acceso y destinatario de la información. Esta información quedará a disposición del responsable institucional de los sistemas y bases de datos, de manera permanente.

Sobre la adquisición de Sistemas a Terceros, se debe establecer un acuerdo previo y formal con instituciones o empresas externas, que incluya cláusulas de seguridad que permitan resguardar la propiedad intelectual, alojamiento de datos en servidores y el uso de cloud computing, además asegure los niveles de confidencialidad de la información necesarios, así como dar cumplimiento a las Políticas y Procedimientos vigentes de Seguridad de la Información del Ministerio de Salud.

Se podrán establecer la firma de contratos de confidencialidad y que estos sean independientes de las obligaciones impuestas por otros documentos a fin de que la obligación de confidencialidad no quede supeditada a la duración del contrato matriz, dado que la obligación de confidencialidad de la información tiene una duración indefinida, desde que es revelada, con prescindencia de vigencia del Contrato. En todo caso, el MINSAL dará una aplicación sistémica y concordante a la obligación de confidencialidad con la de transparencia, establecida en la ley 20.285.

Junto con ello, se deberían incluir las responsabilidades de terceros en la gestión de incidentes de seguridad. Se debe diferenciar entre el encargado de establecer y autorizar los acuerdos con terceros, de los que deban auditar su cumplimiento. El proceso de adquisición del sistema debe ser formal y cumplir con las disposiciones de seguridad establecidas por Minsal para los contratos de tecnologías⁷.

6.8 Lineamiento sobre Tratamiento de datos sensibles para uso en nube y contratos relacionados Marco normativo de la nube⁸.

Desde el ámbito de la seguridad, en específico sobre la Protección de Datos Personales, toda información personal que se recoja almacene, procese y transmita, y en general se haga tratamiento

⁷ Anexo de Seguridad para Contratos de Tecnologías publicado en <http://isalud.minsal.cl/ministerio/dgstic/SGSI/Paginas/default.aspx>

⁸ Los contratos que consideren servicios en la nube deberán cumplir con los lineamientos previstos en la resolución Exenta N° 619 – B de 26 de noviembre de 2018, de la Dirección de Compras y Contratación Pública, que aprueba la directiva de contratación pública N° 32, “Recomendaciones para la contratación de servicios en la nube”.

de ésta, deberían ser diseñado y desarrollado de manera tal que se dé cumplimiento a las obligaciones de reserva o secreto, de acuerdo con la naturaleza de la información.

Los sistemas de acceso remoto a datos deberían ser diseñados de forma tal que sólo puedan ser accedidos desde dentro de la Red de comunicaciones del Ministerio, con canales de comunicación seguros y debidamente protegidos con nombre de usuario y contraseña segura.

De todo proceso que se lleve a cabo sobre el sistema o los datos debe quedar registros detallados y auditables en el sistema, que contengan al menos la identificación del usuario que accede a los datos (requiriente), la descripción del contenido al que accede, el motivo o propósito del acceso, operaciones de tratamiento realizadas, tiempo de retención de los datos y destinatarios de la información.

Los sistemas deberían considerar sistemas de respaldo que permitan la recuperación segura de la información en tiempos razonables para procesos críticos de información, desde la óptica de continuidad de servicios.

Los datos sensibles deberían ser seudonimizados antes de ser ingresados en sistemas “en nube”, debiendo mantenerse en los servidores locales los datos de reidentificación. Consecuentemente, respecto de la contratación de servicios de esta naturaleza se deberían adoptar los siguientes resguardos:

- **Medidas organizativas**
 - Prohibición de uso de la información más allá de las necesidades asociadas al cumplimiento del contrato.
 - **Auditabilidad:** Obligación de que el proveedor mantenga auditorías externas de seguridad y que entregue las evidencias correspondientes.
 - **Notificación de incidentes de seguridad de la información o ciberseguridad:** Obligación de que el proveedor comunique los incidentes que afecten a su servicio, indicando las evidencias que permitan informar a la red de Ciberseguridad del Estado.
 - **Monitoreo y Cumplimiento:** Para una correcta operación de cualquier servicio tecnológico, es fundamental contar monitoreo de los servicios prestados.
 - **Condiciones contractuales:** Se debe definir claramente el alcance de los servicios prestados y los márgenes de crecimiento o reducción elástica del mismo, además de los Acuerdos de Nivel de Servicio (SLA) y las sanciones en caso de incumplimiento
- **Resguardos de legalidad de las cláusulas:** Los contratos no deben considerar cláusulas que están fuera de las competencias del Ministerio, a saber:
 - Prórroga de competencia a tribunales extranjeros o tribunales arbitrales.
 - Renuncia a las responsabilidades del proveedor.
 - Renuncia a las garantías.
 - Aceptación de cláusulas que representen cesiones de datos sensibles o datos personales en hipótesis no autorizadas por la ley
- **Medidas técnicas**
 - **Certificaciones de seguridad:** Los proveedores deben contar con certificaciones acordes a la criticidad de la información que se procese o se almacene en la nube. Tratándose de información crítica y de datos sensibles, como los datos de salud se recomienda el nivel más alto de certificación de acuerdo al estándar generalmente aceptado, de acuerdo a lo que se informe por las áreas técnicas respectivas.
 - **Encriptación de datos:** Tratándose de datos confidenciales que no sean susceptibles de seudonimización deberían aplicarse técnicas de encriptación que permitan asegurar que no serán accedidas ilegítimamente.
 - **Seudonimización:** En caso de información sensible de personas naturales (datos sensibles) se recomienda aplicar técnicas de seudonimización, manteniendo en el servidor local los códigos que permitan la reidentificación de los datos. Esto para evitar que la localización

de datos en países en que existan normas de descriptación forzosa para las autoridades no judiciales ponga en riesgo el deber de secreto que rige de acuerdo a la ley 19.628.

- **Elasticidad:** Se debe tener especial consideración en una planificación adecuada de la capacidad, reservar capacidad con anticipación o definir en el contrato valores de crecimiento flexibles, que no obliguen a realizar un nuevo proceso de compra.

- **Modificación y destrucción de datos**

- El proveedor realiza tratamiento de datos personales por mandato del contratante. En estas circunstancias, toda modificación, cancelación o destrucción de datos debe realizarse de acuerdo a estándares generalmente aceptados, siempre por instrucciones del mandante, debiendo dejarse acta de las operaciones realizadas.
- Definir el acceso y eliminación de los datos tratados, definiendo claramente los períodos mínimos y máximos de retención de datos por parte del prestador de servicios.
- Los dispositivos digitales y magnéticos deben ser sometidos a procedimientos de formateo seguro antes de ser descartados.
- En los procesos de digitalización de información queda prohibido a los proveedores destruir o descartar los originales sin la autorización del mandante.

Se deberían establecer mecanismos para medir al menos los siguientes aspectos:

- Cumplimiento de las medidas de seguridad acordadas.
- Cumplimiento de los niveles de servicio acordados.
- Cumplimiento de las políticas del prestador de servicios.
- Cumplimiento de las medidas asociadas a la destrucción de datos al final del contrato

Se recomienda revisar con detenimiento que los contratos de prestación de servicios especifiquen claramente las mitigaciones a los riesgos identificados y las medidas de seguridad previstas para proteger los datos del servicio. Durante la operación del servicio por parte del proveedor, se debería considerar que se cumplan las políticas y procedimientos de gestión de incidentes establecidos durante la contratación, incluyendo la generación de registros de incidentes y su comunicación oportuna a las partes interesadas.

6.8.1 Seguridad en Nube⁹

Los usuarios de servicios en nube necesitan garantías de que los riesgos asociados al almacenamiento de sus datos y ejecución de sus aplicaciones en estos ambientes son comprendidos y gestionados adecuadamente. Al ser responsabilidad del Prestador de Servicios la implementación de algunas de las medidas de seguridad, se deberá prestar particular atención a que los criterios de seguridad utilizados por el mismo sean reconocidos, transparentes y verificables. Esto puede incluir auditorías o certificaciones externas que cumplan con estas características. Algunos principios de seguridad que los Prestadores de Servicios debieran cumplir son:

- **Controles de acceso, identidad y autenticación robustos tanto en tránsito como en reposo:** El acceso a todas las interfaces de servicio debería restringirse a personas autenticadas y autorizadas para prevenir cambios no autorizados en el servicio del consumidor, robo o modificación de datos o la denegación de servicio.

⁹ Documento de Buenas Prácticas para el uso de Servicios Cloud Computing, Versión 2 19 de febrero de 2018
División de Gobierno Digital

- **Protección de los activos de información y datos, tanto en tránsito como en reposo:** Los centros de datos deberían estar contruidos bajo estándares reconocidos de seguridad, para que los datos, activos y redes estén adecuadamente protegidos contra la manipulación, espionaje, pérdida, daño o incautación. Deberían existir criterios claros sobre el uso de controles criptográficos sobre los datos. Asimismo, debería existir una política clara de retención de datos, y plazos específicos para su posterior eliminación. Es importante que la propiedad de un dato no sea modificada al ser tratada en entornos cloud.
- **Seguridad Operacional, del Personal y Proveedores:** El Prestador de Servicios debería tener procesos y procedimientos establecidos para garantizar la seguridad en la operación del servicio, incluyendo la gestión de su personal y proveedores, incluyendo la posibilidad de vetar personal o proveedores que tengan historiales de incumplimiento normativo o contractual en el ámbito de confidencialidad de la información.
- **Gestión segura de los clientes, incluyendo separación de los mismos y promoción del uso seguro del servicio:** El Prestador de Servicios debería promover el uso seguro de sus servicios por parte de sus clientes, transmitiendo de forma clara las responsabilidades de cada parte cuando se use un servicio en la nube, para que este uso permanezca seguro y para que los datos de sus clientes estén adecuadamente protegidos. Parte de las responsabilidades del Prestador de Servicios en este ámbito es tomar las medidas adecuadas para garantizar la separación lógica o física de los clientes, según corresponda.
- **Proveer información de auditorías a los clientes:** Se debería poder proporcionar a los consumidores los registros de auditoría necesarios para controlar el acceso a su servicio y los datos contenidos en él, puesto que en algunos casos podría ser poco práctico o imposible para el cliente verificar personalmente el correcto cumplimiento de los contratos o acuerdos de servicio, lo que podría forzar a depender de certificaciones y auditorías de terceros. Este acceso debería ser razonable y respetando las políticas de confidencialidad.
- **Marco de gobernanza:** El Prestador de Servicios de servicios debería tener un marco de gobernanza de seguridad que entregue suficiente coordinación y dirija su enfoque en la gestión del servicio y la información que éste contiene.
- **Reporte de incidentes de seguridad:** El Prestador de Servicios debería transparentar al cliente información detallada y oportuna sobre los incidentes de seguridad que afecten el servicio contratado o a la información de éste y adoptar medidas para mitigar los posibles daños resultantes.

6.9 Estructura Documental

Se recomienda definir una estructura documental, para la definición de los controles de seguridad, destinados a mitigar los riesgos, a continuación, se presenta una propuesta (ver Anexo N°3):

N°	Tipo de documento	Finalidad	Responsable de la generación
1	Políticas	Definen los objetivos y directrices a cumplir	Comité de Seguridad de la Información
2	Procedimientos y planes	Detallan los procesos a seguir para cumplir los objetivos	Comité de Seguridad de la Información / Encargado de Seguridad de la Información

3	Instrucciones de trabajo	Acciones detalladas para aspectos concretos a documentar	Cada área de la Institución
4	Registros	Presentan resultados obtenidos o proporcionan evidencia de las actividades desempeñadas	Cada área de la Institución

6.10 Lineamientos de Gestión para la Mejora Continua

Se debería estructurar y mantener un modelo de Gestión de Mejora Continua para el Sistema de Seguridad de la Información de cada Servicio, cuyo plazo de revisión sea en periodos anuales y que permita desarrollar cada uno de los procesos necesarios para mantener en el tiempo los controles de seguridad, con el objetivo de avanzar en la Madurez de los Procesos.

La mejora continua se debería orientar al “Cómo” mantener la gestión en el tiempo y para ello, se recomienda, el uso del Modelo Deming, conocido como PDCA, por sus siglas en ingles de Plan, Do, Check, Act. Pudiendo ser otro modelo equivalente, que propicie una mejora continua.

6.11 Lineamientos en Medición del Nivel de cumplimiento y Niveles de Madurez

A lo menos una vez al año se debería contrastar la aplicación de cada lineamiento como un proceso de control de seguridad de la información, evaluando su nivel de madurez, por auditoría interna de la institución o por una parte no involucrada directamente en dicho control.

Para homogenizar una mirada de avance y desarrollo de los principales procesos necesarios del Sistema de Seguridad de la Información en el Sector Salud, se define una base de medición estandarizada para los Niveles de Madurez de dichos procesos, la que se fundamenta en los niveles de madurez de marcos de referencia internacionales como CMM, CobIT, ISO/IEC 15504. Esto permitirá contrastar la realidad de la institución con cierto nivel deseable como línea base para dicha temática, lo que permite extraer brechas o GAPS y sobre ellas facilitar la planificación de controles de mitigación. Asimismo, se propone analizar los controles de Seguridad de la Información bajo dicho modelo de Niveles de Madurez de Procesos.

Este modelo propuesto a nivel sectorial debería ser adecuado y formalizado como estándar propio de la institución, para facilitar la evolución de sus procesos de gestión.

Se debería priorizar los esfuerzos para alcanzar una línea base de nivel de madurez que será solicitado a nivel sectorial, al menos en los procesos de control que se desee priorizar. Por ejemplo, alcanzar un nivel de madurez 3 o Formalizado, esto consideraría –entre otros- contar con una política y un procedimiento y/o un instructivo, que permita formalizar el quehacer en dicho tema.

El modelo propuesto considera niveles de madurez del proceso, evaluados de 0 a 5 como:

	1 - INICIAL	2 - REPETIBLE	3 - FORMALIZADO	4 - ESTABLECIDO	5 - RESILIENTE
Cultura: No es un tema Documentación: no existe documentación. Registros: no existen Roles Responsabilidades: No existen Tecnología: No existe como un recurso pensado para el proceso. Si está presente es sólo un caso fortuito.	Cultura: Se comparte sólo entre algunos usuarios involucrados la forma de hacer actividades comunes. Documentación: Si bien no se encuentra un documento asociado al proceso, diferentes personas señalan la misma forma de ejecutar las actividades consultadas. Registros: Existen registros, pero no se encuentran estandarizados y/o centralizados. Roles Responsabilidades: Se comparte sólo entre algunos usuarios involucrados la forma de hacer actividades comunes. Tecnología: Cada persona busca la tecnología que más le acomoda.	Cultura: Se comparte de manera informal entre los usuarios involucrados la forma de hacer actividades comunes. Documentación: Se cuenta con un borrador asociado al proceso, en general diferentes personas señalan la misma forma de ejecutar las actividades consultadas. Registros: Las acciones del proceso se registras entre los involucrados de forma estandarizada y/o centralizada; a pesar de no existir un documento formal. Roles y Responsabilidades: Existe acuerdo informal en la distribución de las funciones y se respetan las responsabilidades asociadas; sin mayor cuestionamiento. Tecnología: Se ha comenzado a usar una cierta tecnología estandarizada o definida para el proceso.	Cultura: Se comparte formalmente para toda la institución la manera de desarrollar el proceso, para que todos la conozcan. Los miembros de la organización conocen los procedimientos y documentación asociada a la gestión. Documentación: Existen registros de difusión del proceso y documentación. Existe un documento que referencia al proceso y sus actividades; así como roles y responsabilidades. El documento se encuentra formalizado por el Jefe del Servicio. Registros: Se registran los resultados del proceso, para mantener trazabilidad en el tiempo. Existe registros de a lo menos 3 meses. Roles y Responsabilidades: Se formalizan los roles involucrados, su jerarquía estratégica, táctica y operacional; asimismo están claramente establecidas las responsabilidades de cada uno de ellos, dentro de la documentación formalizada por el Jefe del Servicio. Tecnología: Se he estandarizado una tecnología con una configuración dada y se define un procedimiento para su uso, formalizado por el Jefe del Servicio.	Cultura: La forma de ejecutar el proceso ya es parte de la cultura de la institución. Existen registros de difusión del proceso y documentación. El proceso se encuentra operando a lo menos un año. Documentación: Hay evidencias concretas que el documento que referencia al proceso ha sido actualizado. Existe control y sobre las versiones y su distribución. El documento se encuentra formalizado por el Jefe del Servicio. Registros: Se registran los resultados del proceso; para mantener trazabilidad en el tiempo. Existe registros de a lo menos 1 año. Roles y Responsabilidades: Se formalizan los roles involucrados, su jerarquía estratégica, táctica y operacional; asimismo están claramente establecidas las responsabilidades de cada uno de ellos, Los roles y sus responsabilidades se han revisado y ajustado al menos anualmente, dentro de la documentación formalizada por el Jefe del Servicio. Tecnología: Existe control de versiones, de distribución de las herramientas tecnológicas y versionamiento de sus manuales. Se controlan los pasos a producción de nuevas versiones. Se he estandarizado una tecnología con una configuración dada y se define un procedimiento para su uso, formalizado por el Jefe del Servicio.	Cultura: Existe criterio común de mejorar el proceso y está fuertemente arraigado en la cultura de la institución, adaptándose a los cambios del entorno. Existen registros de difusión del proceso y documentación. El proceso se encuentra operando a lo menos dos años. Documentación: El contenido del documento se somete a revisiones periódicas, contrastándolo con casos extremos y particulares, para hacerlo más completo y robusto. El documento se encuentra formalizado por el Jefe del Servicio. Registros: Se registran los resultados del proceso, para mantener trazabilidad en el tiempo. Existe registros de a lo menos 2 años. Roles y Responsabilidades: Se formalizan los roles involucrados, su jerarquía estratégica, táctica y operacional; asimismo están claramente establecidas las responsabilidades de cada uno de ellos, dentro de la documentación formalizada por el Jefe del Servicio. Tecnología: La tecnología es parte integral del proceso y como tal, se proyecta su innovación junto con el análisis de nuevas tendencias y ajustes del proceso. Existe control de versiones, de distribución de las herramientas tecnológicas y versionamiento de sus manuales. Se controlan los pasos a producción de nuevas versiones. Se he estandarizado una tecnología con una configuración dada y se define un procedimiento para su uso, formalizado por el Jefe del Servicio.

7. CONTROLES DE SEGURIDAD MÍNIMOS A IMPLEMENTAR

A continuación, se presenta un resumen de los controles mínimos a implementar, recomendados por el Ministerio de Interior y el Ministerio de Salud.

7.1 Dominio Nº 5. Políticas de Seguridad de la Información

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Adoptar políticas de seguridad de la información	Objetivo: Proporcionar lineamientos de gestión compatibles con la misión y los objetivos estratégicos de la institución, orientadas a mitigar sus riesgos de seguridad de la información. Disponer de lineamientos para conservar la confidencialidad, integridad y disponibilidad de la información manejada por la institución. Demostrar el compromiso, apoyo e interés de la institución en el fomento y desarrollo de una cultura de seguridad. A.5.1.1 Políticas para la seguridad de la información A.5.1.2 Revisión de las políticas de seguridad de la información	Deberá establecerse un conjunto de políticas de seguridad que se encuentren respaldadas por una planificación estratégica institucional. Los documentos de políticas de seguridad deberán ser: ▪ Aprobados por la dirección de la institución o por el Comité de Seguridad de esta, y ser comunicada y difundida al personal y stakeholders. ▪ Revisados regularmente, al menos cada 2 años, o cuando se produzcan cambios significativos, debiendo realizar las modificaciones necesarias.	▪ Resolución Exenta o similar, con la aprobación de la Política General de Seguridad. ▪ Políticas relevantes por dominio, si las hubiera, debidamente formalizadas. ▪ Evidencia de difusión y revisión de las políticas.

7.2 Dominio Nº 6 Organización de la seguridad de la información

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Designar un encargado de seguridad de la información	Objetivo: Lograr liderazgo y guía en la implementación, operación y mejora del Sistema de Gestión de Seguridad de la Información. A.6.1.1 Roles y responsabilidades de la seguridad de la información	Se debe designar formalmente a un encargado de seguridad de la información, que lidere los esfuerzos de la institución en materia de seguridad de la información, y que reporte directamente al Jefe de Servicio o similar. El encargado de seguridad de la información debe tener un perfil adecuado a sus funciones, además de las cualidades de liderazgo, conocimiento técnico en materias de seguridad de la información y capacidad de gestión. Las funciones del encargado de seguridad de la información deberán estar claramente definidas en la resolución que lo designe.	▪ Resolución Exenta o similar con el nombramiento del Encargado de Seguridad. ▪ Difusión de la designación del Encargado. ▪ Antecedentes que permitan validar que la persona designada cumple con los requisitos mínimos para este rol, tales como certificados de estudios,

			certificaciones técnicas u otros.
Establecer un comité de seguridad	Objetivo: Contar con un equipo de personas con capacidad de decisión sobre los objetivos organizacionales, y que apoyen al encargado de seguridad en su función. A.6.1.1 Roles y responsabilidades de la seguridad de la información. A.6.1.2 Segregación de funciones.	Se debe designar a los integrantes del comité de seguridad de la información de la institución formalmente. El comité de seguridad debe contar con representantes de todas las áreas de la institución donde se identifiquen riesgos de seguridad de la información, incluyendo, al menos, a un representante del área de tecnología. El comité deberá sesionar al menos de forma anual.	- Resolución Exenta o similar con la conformación, responsabilidades y funcionamiento del comité de seguridad. - Difusión de la conformación del comité de seguridad. - Evidencia de sesiones del comité realizadas durante el período.
Segregación de funciones	Objetivo: Reducir el riesgo de negligencia, mal uso o compromiso de la información de la institución. A.6.1.2 Segregación de funciones.	Se debe establecer una política de segregación de funciones que establezca que no se pueda acceder, modificar, utilizar o destruir activos sin autorización o detección, considerando la posibilidad de sabotaje o colusión en las operaciones de la institución. En caso necesario, esta política podrá ser aplicable sólo a algunos procesos o sistemas específicos, limitando su alcance acorde a las necesidades de la institución.	- Política de segregación de funciones con alcance bien definido. - Evidencia de implementación de las políticas de segregación de funciones.
Contacto con autoridades y grupos de interés	Objetivo: Mantener contacto con autoridades y grupos de interés para efectos de gestión de incidentes, información, buenas prácticas, entre otros. A.6.1.3 Contacto con autoridades. A.6.1.4 Contacto con grupos especiales de interés.	Se debe establecer: Un procedimiento con autoridades internas y externas, para el manejo de incidentes de seguridad, incluyendo: medios a través de los que se realizará el contacto, mecanismos de constancia de las comunicaciones y pasos a seguir para realizar el contacto pertinente. Una lista de grupos de interés especial, la que debe ser contactada con regularidad, que permitirán a la institución mantenerse al tanto de las tendencias, normas y métodos de seguridad relevantes. También, se debe mantener contacto con regularidad con el Área de Seguridad del Ministerio de Salud (seguridadtic@minsal.cl) y el CSIRT del Ministerio del Interior y Seguridad Pública. Todos los contactos deben revisarse y hacerse regularmente y, al menos, de forma anual. Se debe instruir la relevancia informar inmediatamente cada vez que se cambie uno de los contactos, tal como sucede con los encargados de ciberseguridad.	- Plan de gestión de incidentes de seguridad que establezca situaciones donde se requiera el contacto con autoridades o grupos de interés. - Evidencia de revisión de las listas de contactos en el intervalo establecido en el documento. Evidencia de contacto con Área de Seguridad de Minsal y el CSIRT del Ministerio del Interior y Seguridad Pública.

7.3 Dominio Nº 7 Seguridad de recursos humanos

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Formalización de los términos de la relación laboral	Objetivo: Los contratos que describen la relación laboral del funcionario y la institución deben indicar las responsabilidades de ambos en cuanto a la seguridad de la información. A.7.1.2 Términos y condiciones de la relación laboral	Cada colaborador contratado bajo la modalidad de honorarios a suma alzada debe firmar un contrato que especifique sus responsabilidades en materia de seguridad de la información. La resolución de ingreso de funcionarios de planta o a contrata debe especificar las responsabilidades del funcionario en materia de seguridad de la información. Como parte del contrato anterior, o en un documento complementario, el funcionario debe firmar un acuerdo de confidencialidad de la información con la institución, en los casos que amerite.	- Listado del personal contratado en el período. - Contratos firmados que pertenezcan al período, con las cláusulas de confidencialidad y seguridad de la información correspondientes. - Acuerdos de confidencialidad firmados que pertenezcan al período, si corresponde.
Responsabilidades de la dirección	Objetivo: Concientizar a los trabajadores respecto de sus responsabilidades, en materias de seguridad de la información. Concretar el compromiso de la dirección en con medidas claras respecto de la seguridad de la información. A.7.2.1 Responsabilidades de la dirección A.7.2.2 Concientización, educación y formación en seguridad de la información.	La dirección de la institución debe impartir instrucciones y orientación sobre seguridad de la información al personal, en intervalos regulares, al menos, sobre las siguientes materias: - Uso seguro de sistemas informáticos, incluyendo estaciones de trabajo. - Uso seguro de la de red interna e internet, incluyendo acceso a recursos compartidos u otros. - Generación, transmisión, recepción, procesamiento y almacenamiento de información. - Procedimientos para el reporte de incidentes. Estas instrucciones podrán ser impartidas mediante actividades personales y/o grupales, o por medio de mecanismos acorde a las necesidades de la institución.	- Programa anual de capacitación y sensibilización en materias de seguridad de la información. - Evidencia de material de capacitación y sensibilización utilizado en el período. - Evidencia de las actividades de capacitación y sensibilización realizadas en el período.

7.4 Dominio Nº 8 Administración de activos

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Identificación de activos de la institución y asignación de sus responsables	Objetivo: Identificar los activos de información de la institución y sus responsables, para garantizar la correcta gestión de seguridad de la información los mismos.	Se debe identificar e inventariar los activos de información de la institución mediante un procedimiento documentado, asignando un responsable para cada uno de los activos mencionados. El inventario de activos debe ser actualizado con una frecuencia, al menos anual.	- Procedimiento o metodología para la generación y actualización del inventario de activos. - Inventario de activos actualizado de la institución.

	A.8.1.1 Inventario de activos. A.8.1.2 Propiedad de los activos.		▪ Responsable de cada activo identificado en el inventario de activos.
Clasificación y etiquetado de activos de la institución	Objetivo: Clasificar y etiquetar los activos de información de la institución para garantizar la correcta gestión de seguridad de la información de estos durante su ciclo de vida. A.8.2.1 Clasificación de la información. A.8.2.2 Etiquetado de la información.	Se debe analizar y valorar cada activo de información con el fin de determinar la necesidad, prioridad y grado de protección que sea apropiado a cada uno. Cada activo debe tener una categoría de clasificación acorde a la necesidad de protección, la que debe estar en conformidad con la Ley Orgánica Constitucional de Bases Generales de la Administración del Estado. Es necesario definir un procedimiento para el etiquetado de los activos acorde a la clasificación realizada, incluyendo el etiquetado en la salida de los sistemas.	▪ Procedimiento o metodología para la generación y actualización del inventario de activos. ▪ Inventario de activos actualizado de la institución. ▪ Clasificación de cada activo identificada en el inventario de activos. ▪ Procedimientos para el etiquetado de activos.
Uso aceptable de los activos de la institución	Objetivo: Garantizar que el personal y stakeholders, conozcan y apliquen los lineamientos de la institución para proteger los activos de información. A.8.1.3 Uso aceptable de los activos A.8.2.3 Manejo de activos	Se debe definir una política de uso aceptable de activos, donde se establezca, al menos, lo siguiente: 1. Las responsabilidades del personal en el cuidado de los activos de la institución. 2. Lineamientos respecto del uso de: correo electrónico, internet y medios de almacenamiento extraíbles, como mínimo. 3. La prohibición del uso de software no autorizado en la institución (ver Instalación de software). Esta política debe estar alineada a lo establecido en el control SP.02.	▪ Política de uso aceptable de activos. ▪ Evidencia de difusión de la política.
Gestión de los medios de almacenamiento	Objetivo: Garantizar la seguridad de la información contenida en medios de almacenamiento. A.8.1.4 Devolución de activos. A.8.2.3 Manejo de activos. A.8.3.1 Gestión de los medios Removibles. A.8.3.2 Eliminación de los medios A.8.3.3 Transferencia física de Medios.	Se deben definir los procedimientos de manejo seguro de medios de almacenamiento, alineada al Uso aceptable de los activos de la institución, incluyendo como mínimo: la solicitud, entrega, uso, transporte, devolución y eliminación de los medios de almacenamiento de la institución. Se debe establecer claramente las restricciones de acceso a los medios de almacenamiento extraíbles en los sistemas.	▪ Procedimientos para la gestión de los medios de almacenamiento. ▪ Evidencia de medidas de seguridad aplicadas a los medios de almacenamiento (encriptación, restricciones de conexión, entre otros). ▪ Evidencia de solicitud, entrega, devolución y eliminación de medios en el período.

7.5 Dominio Nº 9 Control de acceso

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Definición de políticas para el control de acceso lógico	Objetivo: Gestionar el acceso lógico a los sistemas y activos de información de la institución. A.9.1.1 Política de control de acceso A.9.1.2 Accesos a las redes y a los servicios de la red A.9.4.3 Sistema de gestión de contraseñas	Se debe contar con controles de acceso lógico basados, al menos, en un identificador único y su contraseña correspondiente. En el caso de requerimientos más estrictos, se debe privilegiar el uso de sistemas con múltiples factores de autenticación, tales como: firma electrónica, segundas claves (OTP o similar), biometría u otros, como mecanismos de validación más fuertes de la identidad del usuario. Se debe definir una política de gestión de acceso lógico que establezca, al menos, lo siguiente: 1. Métodos de autenticación autorizados por la institución. 2. Métodos de gestión de los identificadores y contraseñas, incluyendo: autorización de acceso, requerimientos mínimos de largo y complejidad, vida útil e historial de uso de contraseñas y clasificación de usuarios privilegiados. En cualquier caso, las contraseñas no podrán ser de largo inferior a 10 caracteres y no podrán estar relacionadas con datos de la persona que hagan fácil su deducción. Si los sistemas de la institución lo soportan, se recomienda el uso de una passphrase en lugar de una contraseña. 3. Métodos de revisión periódica de los accesos lógicos otorgados. 4. Redes y servicios de red de la institución a los que estará permitido el acceso. 5. Lineamientos para establecer quién tiene permitido el acceso a las distintas redes y servicios de la institución. Esta política debe estar basada en los principios de compartimentalización, necesidad de saber y de menor privilegio. De forma adicional, se deben establecer políticas de acceso lógico alineadas con este control para todos los sistemas de información, ya sea en esta misma política o en documentos independientes.	▪ Procedimientos para la gestión de los medios de almacenamiento. ▪ Evidencia de medidas de seguridad aplicadas a los medios de almacenamiento (encriptación, restricciones de conexión, etc). ▪ Evidencia de solicitud, entrega, devolución y eliminación de medios en el período. ▪ Política de gestión de acceso lógico, usuarios y contraseñas. ▪ Políticas complementarias. ▪ Evidencia de difusión de las políticas.
Definición de procedimientos de acceso lógico	Objetivo: Gestionar el acceso lógico a los sistemas y activos de información de la institución. A.9.2.1 Registro y cancelación de registro de usuario A.9.2.2 Asignación de acceso de usuario	Se debe definir procedimientos de gestión de acceso lógico que establezcan, al menos, los siguientes mecanismos: 1. De asignación de información de autenticación a los usuarios, donde el jefe directo de quien lo pide sea el responsable de la solicitud. 2. De alta, baja y modificaciones de usuarios y derechos de acceso, incluyendo los derechos de acceso privilegiado. 3. De entrega segura de la información de autenticación temporal de los usuarios, incluyendo la prohibición de entrega mediante	▪ Procedimientos para la gestión del acceso lógico. ▪ Evidencia de aplicación del procedimiento en los distintos sistemas y servicios de la institución. ▪ Evidencia del proceso de alta, baja y

	A.9.2.3 Gestión de derechos de acceso privilegiados A.9.2.4 Gestión de información secreta de autenticación de usuarios A.9.4.3 Sistema de gestión de contraseñas	texto no protegido y la obligación al usuario de acusar el recibo de esta. 4. Que establezcan la obligación de cambiar la información de autenticación temporal o inicial con el primer uso y por consiguiente, a intervalos regulares. 5. Que establezcan el uso de información de autenticación diferente en los distintos sistemas o servicios de la institución, así como de la información de autenticación de uso personal del usuario. 6. Para minimizar el uso de cuentas grupales. Además de controles y procedimientos para proteger el acceso a los servicios de red.	modificación de usuarios y derechos de acceso. ▪ Evidencia de la entrega segura de contraseñas temporales.
Responsabilidades del usuario en el control de acceso lógico	Objetivo: Responsabilizar a los usuarios del buen uso de los mecanismos de acceso lógico de la institución. A.9.3.1 Uso de información de autenticación secreta A.9.2.4 Gestión de información secreta de autenticación de usuarios	Se debe impartir instrucciones a los usuarios respecto a los mecanismos de control de acceso lógico en, al menos, las siguientes materias: 1. La obligación de mantener, en forma confidencial la información de autenticación que se asigne. 2. La obligación de no registrar la información de autenticación en papel. 3. La obligación de no almacenar la información de autenticación de forma desprotegida. 4. El deber de no compartir la información de autenticación del usuario con otros usuarios. 5. El deber de mantener la información de autenticación grupal sólo dentro de los miembros del grupo. 6. El deber de no incluir la información de autenticación del usuario en procesos automatizados o de inicio de sesión automáticos, por ejemplo, una macro o script. 7. La obligación de cambiar la información de autenticación cuando haya indicios de un posible compromiso de un sistema. Es importante evaluar adecuadamente los factores de autenticación inmutables en estos casos, tales como los factores biométricos.	▪ Procedimientos para la gestión del acceso lógico. ▪ Evidencia de aplicación del procedimiento en los distintos sistemas y servicios de la institución. ▪ Evidencia del proceso de alta, baja y modificación de usuarios y derechos de acceso. ▪ Evidencia de la entrega segura de contraseñas temporales.
Procesos de inicio de sesión seguros	Objetivo: Aplicar mecanismos de inicio de sesión seguro a los sistemas, acorde a la política de control de acceso. A.9.4.2 Procedimientos de inicio de sesión seguro	Para proteger la información contenida en los sistemas de la institución, éstos se deberán configurar de manera que exijan procesos de inicio de sesión seguros y que cumplan, al menos, con lo siguiente: 1. Terminar las sesiones después de un periodo de inactividad. 2. No mostrar la contraseña que se ingresa. 3. Proteger contra los inicios de sesión forzados. 4. No transmitir la información de autenticación sin cifrar.	▪ Procedimientos para la gestión del acceso lógico. ▪ Evidencia de aplicación del procedimiento en los distintos sistemas y servicios de la institución. ▪ Evidencia del proceso de inicio de sesión seguro en los distintos sistemas y servicios de la institución.

7.6 Dominio N° 10 Criptografía

PROCESO / CONTROL	OBJETIVO // CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Definiciones sobre el uso de controles criptográficos	Objetivo: Proteger la confidencialidad, integridad y autenticidad de la información de la institución mediante el correcto uso de la criptografía. A.10.1.1 Política sobre el uso de controles criptográficos A.10.1.2 Gestión de claves	Se debe establecer una política de uso de controles criptográficos para la institución que aborde, al menos, los siguientes temas: 1. Mecanismos de cifrado para proteger la información de la institución (por ejemplo, cifrado de discos duros, respaldos u otros). 2. Uso y gestión de certificados digitales en la institución, ya sea para firma electrónica, firma electrónica avanzada u otros usos. 3. Uso de mecanismos criptográficos para el establecimiento de canales seguros para comunicaciones, tales como correo electrónico, VPN, SSL/TLS (HTTPS), IPSec, SSH u otros, incluyendo el uso y gestión de llaves y certificados digitales para estos fines. 4. Listado de algoritmos o protocolos criptográficos inseguros, y de uso prohibido en las instituciones, salvo en caso de excepciones debidamente justificadas por la autoridad competente. Este listado debe contener, al menos, los siguientes: a) MD4, MD5, SHA-1. b) DES, 3DES. c) RC4. d) RSA o DSA con largo de llaves igual o inferior a 1024-bits. e) Criptografía basada en curvas elípticas con largo de llaves igual o inferior a 160-bits. f) Cualquier tipo de algoritmo criptográfico "casero" o implementaciones "caseras" de algoritmos criptográficos existentes.	▪ Política de uso de controles criptográficos. ▪ Política de gestión de llaves criptográficas, si corresponde. ▪ Listado de sistemas que utilizan firma electrónica avanzada u otros mecanismos criptográficos.

7.7 Dominio N° 11 Seguridad física y ambiental

PROCESO / CONTROL	OBJETIVO // CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Implementación de políticas de acceso físico	Objetivo: Proteger las instalaciones de procesamiento de accesos no autorizados, robos, mal uso o daños producto de peligros ambientales. A.11.1.1 Perímetro de seguridad física A.11.1.2 Controles de acceso físico	Se debe establecer una política de seguridad física alineada a lo establecido en las políticas para el control de acceso lógico y al análisis de riesgos realizado por la institución. Adicionalmente, se deben establecer todos los procedimientos necesarios para su implementación. Se debe definir los perímetros de seguridad física donde se alojen los activos que den soporte a los servicios de la institución (áreas seguras). Dichos perímetros deben tener barreras de resguardo, controles de acceso apropiados y estar físicamente protegidos del acceso no autorizado, daños e interferencias, así como proveer instalaciones de apoyo tales como cableado y suministro eléctrico apropiados.	▪ Política de seguridad física. ▪ Procedimientos necesarios para la implementación de las políticas de seguridad física. ▪ Listado de áreas seguras de la institución y personal autorizado para acceder a ellas.

		Se debe establecer un procedimiento de acceso a las áreas seguras y designar al personal autorizado para acceder a éstas.	■ Registros de acceso a las áreas seguras.
Implementación de controles ambientales en áreas seguras	Objetivo: Proteger el equipamiento de daño producto de accesos no autorizados, robos o peligros ambientales, permitiendo la continuidad operacional y reducir el daño ante la materialización de algún desastre. A.11.1.4 Protección contra amenazas externas y del ambiente. A.11.2.1 Ubicación y protección del equipamiento. A.11.2.4 Mantenimiento del equipamiento.	Se debe establecer una política de seguridad del equipamiento alineada a lo establecido en las políticas de acceso físico que aborde, al menos, los siguientes temas: 1. Ubicación del equipamiento, de forma de minimizar el acceso innecesario y percances producto de mala manipulación o descuidos. 2. Implementación de controles de seguridad física, de forma de minimizar el riesgo de, al menos, las siguientes amenazas ambientales: robos, incendios, humo, agua, vibraciones o terremotos, interferencia del suministro eléctrico. 3. Mecanismos para el monitoreo y control de las condiciones ambientales tales como humedad, temperatura, etc. 4. Mecanismos para la detección temprana y extinción de incendios. 5. Mecanismos para garantizar la mantención periódica del equipamiento.	■ Política de seguridad del equipamiento. ■ Evidencia de controles de seguridad física implementados. ■ Contratos con proveedores relacionados (alarmas, extintores, refrigeración, etc). ■ Evidencia de los mecanismos de monitoreo ambiental y sus últimas alertas y/o pruebas de funcionamiento. ■ Evidencias del mantenimiento realizado al equipamiento.
Seguridad en la reutilización o descarte de equipos	Objetivo: Prevenir pérdida de confidencialidad de la información de la institución durante o después de descartar o desechar equipamiento. A.11.2.7 Seguridad en la reutilización o descarte de equipos	Se debe establecer una política de reutilización o descarte de activos, incluyendo al menos: requisitos para los mecanismos de borrado, sobreescritura o destrucción de activos y tipo de información correspondiente a mecanismos, alineado a la clasificación establecida la política o procedimiento de etiquetado de activos. Se debe establecer un procedimiento de borrado seguro de equipamiento tecnológico que establezca, al menos, lo siguiente: 1. Los datos de la institución deben ser eliminados o sobrescritos de manera segura, y con un mecanismo que entregue un alto grado de confianza en que la información no se pueda recuperar, antes de reutilizar o descartar el equipamiento. 2. La prohibición de un formateo normal, en el caso de descarte de Equipos, debiendo de forma obligatoria requerir un borrado seguro de los medios. 3. Para el caso de datos sensibles, que así lo ameriten, el medio de almacenamiento deberá ser destruido de forma segura. Una alternativa al borrado seguro es utilizar encriptación de la información, de forma tal que, al destruir la llave de encriptación, la información no se pueda recuperar (ver Dominio N°10 Criptografía).	■ Política de reutilización o descarte de activos. ■ Procedimientos para el borrado seguro o destrucción de medios de almacenamiento.

Implementación de políticas de escritorio y pantalla limpias	Objetivo: Proteger el equipamiento de daño producto de descuidos o accidentes. Proteger la información de la institución de accesos no autorizados a ella. A.11.2.1 Ubicación y protección del equipamiento A.11.2.8 Equipo de usuario desatendido A.11.2.9 Política de escritorio y pantalla limpios	Se debe establecer una política de escritorio y pantalla limpios que aborde, al menos, lo siguiente: 1. La prohibición de consumo de alimentos, bebidas o tabaco en las cercanías del equipamiento, en particular en áreas seguras. 2. La obligación del cierre o bloqueo de sesión una vez terminadas las funciones y antes de levantarse del puesto de trabajo, forzando el uso de algún mecanismo de autenticación para su posterior uso. 3. La obligación de la mantención de un escritorio limpio de papeles o medios de almacenamiento con información de la institución.	▪ Política de escritorio y pantalla limpia. ▪ Evidencia de difusión de la política.
--	--	--	--

7.8 Dominio N° 12 Seguridad de las operaciones

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Implementación de controles contra código malicioso	Objetivo: Proteger la información de la institución contra el código malicioso. A.12.2.1 Controles contra código malicioso	Se debe establecer una política contra código malicioso, así como todos los procedimientos necesarios para su implementación, que establezcan al menos, lo siguiente: 1. Características de la solución contra código malicioso de la institución (si es centralizada o no, si posee funcionalidad de lista blanca, gris o negra, frecuencia de actualización de las firmas, entre otros). 2. Capacitaciones necesarias al personal respecto al uso de las herramientas contra código malicioso y conductas de riesgo asociadas a código malicioso, como, por ejemplo, abrir archivos adjuntos de un correo electrónico, uso de medios de almacenamiento extraíbles en computadores no seguros, etc. 3. Implementación de mecanismos de detección y limpieza de código malicioso. Estas capacitaciones deben estar alineadas a las Responsabilidades de la dirección (capacitación) y el uso aceptable de los activos de información.	▪ Política y procedimiento contra código malicioso. ▪ Evidencia de capacitaciones al personal respecto a conductas de riesgo asociadas a código malicioso. ▪ Evidencia de aplicación de Procedimiento de detección y limpieza de componentes del sistema.
Respaldo de la información	Objetivo: Proteger la información de la institución en casos como pérdida de datos y restauración de éstos. A.12.3.1 Respaldo de la información.	Se debe establecer una política de respaldos, así como todos los procedimientos necesarios para su implementación, estableciendo claramente los requerimientos, los que deben incluir, al menos, lo siguiente: 1. Sistemas o equipamiento que debe ser respaldado. 2. Periodicidad de los respaldos de las estaciones de trabajo, que no podrá ser menor a un respaldo anual.	▪ Política de respaldos. ▪ Procedimientos de respaldos para los sistemas y estaciones de trabajo definidas en la política. ▪ Procedimientos de restauración de los respaldos.

		3. Periodicidad de los respaldos de los sistemas de información, que no podrá ser inferior a un respaldo mensual. 4. Retención de los respaldos, que no podrá ser inferior a tres ciclos de respaldo para los sistemas de información. 5. Infraestructura necesaria para el almacenamiento de los respaldos. 6. Ubicación de la infraestructura de almacenamiento de los respaldos, que deberá estar ubicada, de forma tal, que minimice el riesgo de ser afectada por los mismos incidentes que la ubicación de los sistemas de información. 7. Requerimientos de seguridad para la infraestructura de almacenamiento de los respaldos, incluyendo controles de acceso y condiciones físicas y ambientales. 8. Realización de pruebas de restauración de los respaldos de los sistemas de información, que no podrá ser inferior a una prueba anual por sistema, debiendo quedar documentadas. 9. Los procedimientos de restauración de los respaldos deben estar disponibles en caso de querer utilizarlos, ya sea almacenando dichos procedimientos de forma conjunta con los respaldos o en alguna ubicación que asegure su disponibilidad.	▪ Evidencia de realización de respaldos acorde a las políticas. ▪ Evidencia de pruebas de restauración de los respaldos. ▪ Evidencia de controles de seguridad implementados en la infraestructura de almacenamiento de respaldos.
Sincronización de Reloj	Objetivo: Facilitar el seguimiento de los eventos y la consistencia de los registros de los sistemas de la institución. A.12.4.4 Sincronización de relojes	Se debe establecer una política de sincronización de relojes, así como todos los procedimientos necesarios para su implementación, los que deben incluir, al menos, lo siguiente: 1. Establecimiento de la fuente de tiempo para los sistemas de la institución a la hora oficial de Chile. 2. Mecanismos para mantener la sincronización de los relojes en los sistemas de la institución.	▪ Política de sincronización de relojes. ▪ Procedimientos operacionales de los sistemas de la institución que incluyan la sincronización de relojes. ▪ Evidencia de la correcta sincronización de los relojes de los sistemas de la institución.
Instalación de software	Objetivo: Asegurar la integridad de los sistemas de la institución. A.12.5.1 Instalación del software en sistemas operacionales A.12.6.2 Restricciones sobre la instalación de software	Se debe establecer, en alguna de las políticas de seguridad de la institución (por ejemplo, en la política de uso aceptable de activos, control AA.03), la prohibición del uso de software no autorizado. Se debe establecer un procedimiento de instalación de software que abarque, al menos, lo siguiente: 1. Instalación de software en sistemas. 2. Instalación de software en estaciones de trabajo. 3. Listado de software permitido, incluyendo software base, los tipos de software que puedan instalar los usuarios o software que requiera algún tipo de autorización especial. 4. Listado de software o categorías de software prohibido. 5. Mecanismos de revisión de software instalado en la institución.	▪ Establecimiento de la prohibición del uso de software no autorizado en alguna política de la institución. ▪ Procedimiento de instalación de software. ▪ Evidencia de los resultados de las revisiones de software instalado en la institución.

7.9 Dominio N° 13 Seguridad en las comunicaciones

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Implementación de controles de seguridad en las redes	Objetivo: Proteger la información en sistemas y aplicaciones de la institución mediante la administración y control de las redes. A.13.1.1 Controles de red	Se debe establecer una política de seguridad de red, así como todos los procedimientos necesarios para su implementación, los que deben incluir, al menos, lo siguiente: 1. Mecanismos y responsabilidades para la administración de equipos de redes. 2. Mecanismos de autorización del acceso a las distintas redes y sistemas de red. 3. Mecanismos para controlar y/o restringir la conexión a las distintas redes y sistemas de red internos y externos.	▪ Política de seguridad de red. ▪ Listado de controles de red implementados y procedimientos para su correcto uso. ▪ Evidencia de los controles de red implementados.
Políticas y procedimientos para la transferencia de información	Objetivo: Mantener la seguridad de la información transferida al interior o exterior de la institución. A.8.3.3 Transferencia física de medios. A.13.2.1 Políticas y procedimientos de transferencia de información. A.13.2.3 Mensajería electrónica.	Se debe establecer una política de comunicaciones seguras, así como todos los procedimientos necesarios para su implementación, los que deben incluir, al menos, lo siguiente: 1. Medidas de protección para la transferencia de información a través de cualquier medio de comunicación, incluyendo los de transporte físico. 2. Medidas para la protección de la información transferida contra la interceptación, copia, modificación y/o destrucción. 3. Medidas para la detección y protección contra el código malicioso que se pueda transmitir por medios electrónicos, alineadas al control SO.01. 4. Los lineamientos para el uso aceptable de los mecanismos de transferencia de información, en relación con el uso aceptable de los activos de información. 5. Uso de controles criptográficos para proteger la información transferida, alineado al (ver Dominio N° Criptografía). 6. Disponer de controles adicionales para los mensajes que no se puedan autenticar.	▪ Política y procedimientos para comunicaciones seguras. ▪ Evidencia de configuración de sistemas de transferencia de información acorde a la política, tales como correo electrónico, mensajería electrónica y otros.

7.10 Dominio N° 14 Adquisición, desarrollo y mantenimiento de sistemas

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Incluir requisitos de seguridad de la información en los procesos de adquisición o desarrollo de sistemas	Objetivo: Incorporar la seguridad de la información al ciclo de vida de los sistemas de la institución. A.14.1.1 Análisis y especificación de requisitos	Los requisitos de seguridad de la información deben ser definidos e incluidos en los procesos, proyectos de adquisición, desarrollo de nuevos sistemas o mejora de sistemas existentes.	▪ Evidencia de incorporación de requisitos de seguridad de la información en los proyectos de adquisición, desarrollo o



	de seguridad de la información.		mejora de sistemas.
Política de desarrollo Seguro	Objetivo: Las reglas para el desarrollo de software y de sistemas deben ser establecidas y aplicadas a los desarrollos dentro de la organización. A.14.2.1: Política de Desarrollo Seguro.	Se deberían establecer reglas para el desarrollo de software y sistemas y, se deberían aplicar a los desarrollos dentro de la organización. El desarrollo seguro es un requisito para generar un servicio, arquitectura, software y sistema seguro. Dentro de una política de desarrollo seguro se deberían considerar los siguientes aspectos: a. seguridad del entorno de desarrollo; b. orientación sobre la seguridad del ciclo de vida del desarrollo de software: 1) seguridad en la metodología de desarrollo de software; 2) pautas de codificación segura para cada lenguaje de programación que se utiliza; c. requisitos de seguridad en la fase de diseño; d. puntos de verificación de seguridad dentro de los hitos del proyecto; e. repositorios seguros; f. seguridad en el control de la versión; g. conocimiento de seguridad de aplicación necesario; h. capacidad de los desarrolladores de evitar, encontrar y solucionar la vulnerabilidad. Si se externaliza el desarrollo, la organización debería obtener la garantía de que la parte externa cumple con estas reglas para el desarrollo seguro (ver Supervisión de desarrollo de Terceros)	▪ Política de Desarrollo seguro. ▪ Evidencia de su difusión e implementación en los desarrollos.
Procedimiento de control de cambios	Objetivo: Los cambios a los sistemas dentro del ciclo de desarrollo deben ser controlados mediante el uso de procedimientos formales de control de cambios. A.14.2.2 Procedimientos de control de cambios del sistema.	La introducción de nuevos sistemas y cambios importantes a los sistemas existentes debería seguir un proceso formal de documentación, especificación, pruebas, control de calidad e implementación administrada. El proceso debería incluir una evaluación de riesgos, un análisis de los impactos de los cambios y la especificación de los controles de seguridad necesarios. Este proceso además de garantizar que no se vean comprometidos los procedimientos de seguridad y control, que los programadores de soporte cuenten con acceso solo para las partes del sistema necesarias para su trabajo y que se obtenga el acuerdo y la aprobación formal para cualquier cambio.	▪ Procedimiento de control de cambios en los sistemas. ▪ Registros de control de cambios en los sistemas.
Supervisión de los desarrollos de terceros	Objetivo: La organización debe supervisar y monitorear la actividad del desarrollo del sistema tercerizado. A.14.2.7 Desarrollo tercerizado.	Cuando se subcontrata el desarrollo de sistemas, los siguientes puntos deben ser considerados a través de la toda la cadena de suministro externo de la organización: ▪ acuerdos de licencia, de propiedad de código y derechos de propiedad intelectual relacionados con el contenido subcontratado; ▪ los requisitos contractuales para el diseño seguro, codificación y prácticas de prueba;	▪ Política y procedimiento para la supervisión de desarrollos tercerizados. ▪ Registros de la gestión de la seguridad en los proyectos, de acuerdo con la

		- las pruebas de aceptación de calidad y la precisión de los entregables; - la provisión de evidencia de que las pruebas suficientes se han aplicado para protegerse contra la presencia de contenido malicioso (intencional o no intencional) sobre los entregables; el suministro de evidencia de que las pruebas suficientes se han aplicado para proteger contra la presencia de vulnerabilidades conocidas.	política y procedimiento. Registros de cláusulas de confidencialidad y seguridad en los contratos con terceros.
Pruebas de seguridad y aceptación en los sistemas	Objetivo: Durante el desarrollo se debe realizar la prueba de funcionalidad de seguridad. Definir los programas de prueba de aceptación y los criterios pertinentes para los nuevos sistemas de información, actualizaciones y versiones nuevas. A.14.2.8 Prueba de seguridad del sistema A.14.2.9 Prueba de aprobación del sistema	Los sistemas nuevos y actualizados se deberían someter a pruebas y verificaciones exhaustivas durante los procesos de desarrollo, incluida la preparación de un programa de actividades detallado y entradas de pruebas y los resultados esperados bajo una variedad de condiciones. Para los desarrollos internos, dichas pruebas las debería realizar inicialmente el equipo de desarrollo. Las pruebas de aceptación independientes se deberían realizar (tanto para los desarrollos internos y externalizados) para garantizar que el sistema funciona según se espera y solo como se espera. El alcance de las pruebas debería ser en proporción a la importancia y naturaleza del sistema. Las pruebas de aceptación del sistema deberían incluir las pruebas de los requisitos de seguridad de la información y la adherencia a las prácticas de desarrollo del sistema seguro. Las pruebas también se deberían realizar en los componentes y sistemas integrados recibidos. Las pruebas se deberían realizar en un entorno de pruebas realista para garantizar que el sistema no introducirá vulnerabilidades al entorno de la organización y que las pruebas sean confiables.	Evidencia de pruebas de seguridad y aceptación de sistemas.

7.11 Dominio Nº 15 Relaciones con los proveedores

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Políticas de seguridad para las relaciones con proveedores	Objetivo: Mantener la seguridad de la información de los activos de la institución a los que tengan acceso proveedores. A.15.1.1 Política de seguridad de la información para las relaciones con el proveedor	Se debe establecer una política de seguridad para las relaciones con proveedores, que establezca los requisitos de seguridad que deben cumplir, alineada a los objetivos estratégicos de la institución y a sus políticas de seguridad.	Política de seguridad para las relaciones con proveedores.
Gestionar los cambios en los servicios de los proveedores	Objetivo: Gestionar los cambios al suministro de los servicios por parte de los proveedores, incluido el mantenimiento y la mejora de las políticas de seguridad	Se deberían considerar los siguientes aspectos: - Cambios a los acuerdos del proveedor; - Los cambios realizados por la organización para implementar: ✓ mejoras a sus servicios;	Registros de gestión de cambios cuando se producen cambios en los servicios de los proveedores.

	de la información existentes, procedimientos y controles, al considerar la criticidad de la información del negocio, los sistemas y procesos involucrados y la reevaluación de los riesgos. A.15.02.02 Gestión de cambios a los servicios del proveedor.	✓ desarrollo de cualquier nueva aplicación y sistemas; ✓ las modificaciones o actualizaciones de las políticas y procedimientos de la organización; ✓ controles nuevos o cambiados para resolver incidentes de seguridad de la información y mejorar la seguridad; Cambios en los servicios del proveedor para implementar: cambios y mejoras en las redes; uso de nuevas tecnologías; adopción de nuevos productos o nuevas versiones; nuevas herramientas y entornos de desarrollo; cambios en la ubicación física de las instalaciones de servicios; cambio de proveedores; subcontratación a otro proveedor.	
--	---	---	--

7.12 Dominio N° 16 Administración de incidentes de seguridad de la información

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Políticas y procedimientos para la gestión de incidentes	Objetivo: Asegurar un enfoque consistente y eficaz en la gestión de los incidentes de seguridad de la información de la institución. A.16.1.1 Responsabilidades y procedimientos A.16.1.2 Informe de eventos de seguridad de la información A.16.1.4 Evaluación y decisión sobre los eventos de seguridad de la información A.16.1.5 Respuesta ante incidentes de seguridad de la información A.16.1.6 Aprendizaje de los incidentes de seguridad de la información	Se debe establecer una política de gestión de incidentes de seguridad de la información que establezca, al menos, lo siguiente: 1. Los roles y responsabilidades asociados a la gestión de incidentes. 2. Deber de informar los incidentes a la autoridad correspondiente o grupos de interés. Se debe establecer un procedimiento de respuesta ante incidentes de seguridad que establezca, al menos, lo siguiente: 1. Mecanismos de detección de incidentes de seguridad. 2. Mecanismos para el registro, reporte y clasificación de los incidentes de seguridad. 3. Evaluación de los incidentes de seguridad y respuesta a ellos. 4. Seguimiento de los incidentes y mejora continua.	▪ Política de gestión de incidentes de seguridad de la información. ▪ Responsables de la gestión de incidentes formalmente definidos. ▪ Listado de incidentes del período.

7.13 Dominio N° 17 Aspectos de la seguridad de la información de la administración de la continuidad del Negocio

PROCESO / CONTROL	OBJETIVO / CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Establecimiento de un plan de continuidad del negocio	Objetivo: Mantener la continuidad de las operaciones y de la seguridad de la información de la institución durante situaciones de contingencia o emergencia.	Se debe establecer un plan de continuidad del negocio que aborde, al menos, lo siguiente:	▪ Plan de continuidad del negocio, que incorpore un plan de contingencia y recuperación.

	Mitigar el daño que un evento de continuidad podría causar a la institución. Volver a la operación normal de forma segura y ordenada después de un evento que afecte la continuidad de las operaciones. A.17.1.1 Planificación de la continuidad de la seguridad de la información. A.17.1.2 Implementación de la continuidad de la seguridad de la información. A.17.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información.	1. Definición de roles y responsabilidades durante y después de contingencia. 2. Proceso para declarar la contingencia y convocar a los equipos de respuesta. 3. Detalles para gestionar las consecuencias de un evento de contingencia en, al menos, los siguientes aspectos: a. Seguridad de las personas. b. Opciones y mecanismos de respuesta a la contingencia, incluyendo las definiciones de seguridad de la información durante los eventos de contingencia. c. Mitigación y prevención de futuros daños producto del incidente en curso. 4. Detalles respecto a la comunicación con colaboradores, funcionarios y sus familiares, stakeholders y autoridades (policía, bomberos, autoridades directivas, etc.) 5. Detalles respecto a la continuidad de las operaciones críticas durante la contingencia. 6. Detalles respecto a la efectiva gestión de las relaciones públicas durante la contingencia. 7. Proceso para la vuelta a la normalidad, una vez terminada la contingencia. Adicionalmente, se debe establecer un plan de pruebas de continuidad del negocio, que establezca una frecuencia de pruebas al menos anual, así como también que los resultados de dichas pruebas deben resultar en la mejora continua del plan de continuidad del negocio.	▪ Plan de pruebas del plan de continuidad del negocio. ▪ Resultados de las pruebas al plan de continuidad de negocio.
--	---	---	---

7.14 Dominio Nº 18 Cumplimiento

PROCESO / CONTROL	OBJETIVO // CONTROLES NCH-ISO 27001:2013	DESCRIPCIÓN DE LA IMPLEMENTACIÓN	MEDIO VERIFICACIÓN
Identificar y documentar los requerimientos legales y contractuales	Evitar incumplimientos de cualquier tipo de obligación legal o contractual relacionadas con la seguridad de la información. A.18.1.3 Protección de los registros	Se debe identificar y documentar todos los requerimientos legales y contractuales relacionados con la seguridad de la información que apliquen a la institución. Se debe establecer un procedimiento para asegurar el cumplimiento de dichos requisitos.	▪ Resolución Exenta o similar con la aprobación de la Política General de Seguridad, con un apartado referido a la obligación del cumplimiento legal y normativo. ▪ Planilla o documento similar, donde se identifique: los



			requerimientos legales y contractuales de la institución, estado de su cumplimiento y plan de acción para requerimientos no cumplidos.
Establecer mecanismos de protección de los registros.	Proteger los registros de operación de la institución contra cualquier modificación no autorizada o accidental que comprometa la confidencialidad, integridad o disponibilidad de ellos.	Se debe establecer un procedimiento para auditar, de forma periódica, la integridad de los registros de operación de la institución, de conformidad con los requisitos legales y contractuales identificados.	- Resolución Exenta o similar con la aprobación de la Política General de Seguridad, con un apartado referido a la obligación del cumplimiento legal y normativo. - Planilla o documento similar, donde se identifique: los requerimientos legales y contractuales de la institución, estado de su cumplimiento y plan de acción para requerimientos no cumplidos.
Establecer mecanismos de protección de la información personal	Asegurar y proteger la información de carácter personal que maneje la institución contra cualquier brecha de confidencialidad o privacidad. .18.1.4 Privacidad y protección de la información de identificación personal	Se debe establecer una política de privacidad, que establezca claramente la protección de la información personal que maneje la institución y los mecanismos que utiliza para garantizar su confidencialidad y privacidad.	Política de privacidad y protección de datos personales.

8. APROBACIÓN Y CONTROL DE VERSIONES

Responsable		Fecha
Elaborado	Rodrigo Vidal Arteaga / Unidad de Seguridad TIC	abril 2021
Revisado	José Villa Catalan / Encargado Ciberseguridad	mayo 2021
Aprobado	Gino Peirano Alvarado /Jefe Departamento TIC	mayo 2021

Versión cambios	Fecha de emisión	Autor cambios	Motivo del cambio	Secciones modificadas
V 1.0	abril 2021	Rodrigo Vidal Arteaga	Creación del documento	Preparación del documento
V1.2	mayo 2021	Rodrigo Vidal Arteaga / José Villa Catalan	Revisión de cuerpo del informe e incorporación recomendaciones CSIRT	Revisión de Informe
V 1.3	mayo 2021	Gino Peirano Alvarado	Aprobado	Aprobado

9.- ANEXO 1: PANORAMA REGULATORIO CIBERSEGURIDAD NACIONAL, LEYES RELATIVAS A LA CIBERSEGURIDAD

LEYES Y DECRETOS

1. Normas Constitucionales.

- Artículo 19, catálogo de derechos fundamentales:
 - N°4 , sobre protección de la vida privada y la protección de datos personales.
 - N°5, sobre inviolabilidad de las comunicaciones privadas, el hogar y los documentos privados.
 - N°9, sobre el derecho a la protección de la salud de las personas
 - N°12, que garantiza la libertad de expresión y de información.

<https://www.bcn.cl/leychile/navegar?idNorma=242302>

2. Normas legales.

- DFL N° 1, de 2005, fija texto refundido, coordinado y sistematizado del decreto ley N° 2.763, de 1979 y de las leyes n° 18.933 y n° 18.469.
- Ley 20.584, de derechos y deberes de los pacientes.
- Ley N°19.223, tipifica figuras penales relativas a la informática.
<https://www.bcn.cl/leychile/navegar?idNorma=30590>
- Código penal, que tipifica los delitos tradicionales de fraude, estafas, delitos contra la propiedad, contra la vida privada. Etc.
<https://www.bcn.cl/leychile/navegar?idNorma=1984>
- Ley N°19.628, sobre protección de la vida privada.
<https://www.bcn.cl/leychile/navegar?idNorma=141599>
- Ley N°19.799, sobre documentos electrónicos, firma electrónica y servicios de certificación de dicha firma.
<https://www.bcn.cl/leychile/navegar?idNorma=196640>
- Código Procesal Penal. Fija normas para realizar una investigación y establece medidas intrusivas contra la vida privada.
<https://www.bcn.cl/leychile/navegar?idNorma=176595>
- Ley N°20.285, sobre el acceso a la información pública.
<https://www.bcn.cl/leychile/navegar?idNorma=276363>
- Ley N°21.113, declara octubre como el mes de la Ciberseguridad.
<https://www.bcn.cl/leychile/navegar?idNorma=1123489>
- Ley N°18.168, Ley General de Telecomunicaciones.
<https://www.bcn.cl/leychile/navegar?idNorma=29591>
- Ley N° 20.009 sobre Extravío, Robo o Hurto de Tarjetas de crédito y débito.
<https://www.bcn.cl/leychile/navegar?idNorma=236736>

- Ley N°20.453, que consagra el principio de neutralidad en la red.
<https://www.bcn.cl/leychile/navegar?idNorma=1016570>
- Ley N°20.478, sobre recuperación y continuidad en condiciones críticas y de emergencia del sistema público de telecomunicaciones.
<https://www.bcn.cl/leychile/navegar?idNorma=1020622>
- Ley N°19.974, sobre el Sistema de Inteligencia del Estado y crea la Agencia Nacional de Inteligencia.
<https://www.bcn.cl/leychile/navegar?idNorma=230999>
- Ley N°21.180 sobre Transformación Digital del Estado.
<https://www.bcn.cl/leychile/navegar?idNorma=1138479&idParte=10067375&idVersion=2222-02-02>
- Ley N°19.913, que crea la unidad de análisis financiero y modifica diversas disposiciones en materia de lavado y blanqueo de activos.
<https://www.bcn.cl/leychile/navegar?idNorma=219119>
- Ley N° 20.575, que establece el principio de finalidad en el tratamiento de datos personales.
<https://www.bcn.cl/leychile/navegar?idNorma=1037366>

PROYECTOS DE LEY:

- Proyecto de ley de delitos informáticos, que establece normas sobre delitos informáticos, deroga la ley N° 19.223 y modifica otros cuerpos legales con el objeto de adecuarlos al convenio de Budapest. Boletín 12192-25.
<https://www.senado.cl/appsenado/templates/tramitacion/index.php#>
- Proyecto de ley de protección de datos personales, que regula la protección y el tratamiento de los datos personales y crea la Agencia de Protección de Datos Personales. Boletín 11144-07.
<https://www.senado.cl/appsenado/templates/tramitacion/index.php#>
- Proyecto de ley de Infraestructura crítica, que modifica la Ley Orgánica Constitucional de las Fuerzas Armadas para establecer el rol de éstas en la protección de la infraestructura crítica del país cuando sea indispensable para la seguridad nacional. Boletín 13088-02.
<https://www.senado.cl/appsenado/templates/tramitacion/index.php#>
- Proyecto de ley de inteligencia, que fortalece y moderniza el sistema de inteligencia del Estado. Boletín 12234-02.
<https://www.senado.cl/appsenado/templates/tramitacion/index.php#>
- Proyecto de ley de neuroderechos, sobre protección de los neuroderechos y la integridad mental, y el desarrollo de la investigación y las neurotecnologías. Boletín 13828-19
<https://www.senado.cl/appsenado/templates/tramitacion/index.php#>
- Proyecto de ley de portabilidad eléctrica, que establece el derecho a la portabilidad eléctrica. Boletín 13782-08.
<https://www.senado.cl/appsenado/templates/tramitacion/index.php#>

Normas reglamentarias.

- Instructivo Presidencial N°1, que aprueba la Política Nacional de Ciberseguridad y ordena su implementación en el sistema público.
<https://transparenciaactiva.presidencia.cl/Otros%20Antecedentes/Inst-Pres-N-001.pdf>
- Instructivo Presidencial N°8, que impartió instrucciones en materia de ciberseguridad, para la protección de redes, plataformas y sistemas informáticos de los órganos de la Administración del Estado.
<https://transparenciaactiva.presidencia.cl/instructivos/Instructivo-2018-008.pdf>
- D.S. N°533/2015, crea Comité Interministerial sobre Ciberseguridad: crea un Comité interministerial con el objetivo de preparar una propuesta de Política Nacional de ciberseguridad y asesorar al gobierno de materias de ciberseguridad.
<https://www.bcn.cl/leychile/navegar?idNorma=1079608>
- D.S. N°579 que modifica el decreto supremo n° 533, de 2015, del ministerio del interior y seguridad pública, modificando el objetivo del comité, precisando sus funciones y creando una comisión técnica asesora en materia de Ciberseguridad.
<https://www.bcn.cl/leychile/navegar?idNorma=1140740>
- D.S. N°83/2005, aprueba norma técnica para los órganos de la administración del estado sobre seguridad y confidencialidad de los documentos electrónicos.
<https://www.bcn.cl/leychile/navegar?idNorma=234598&idParte=>
- D.S. N°93, aprueba norma técnica para la adopción de medidas destinadas a minimizar los efectos perjudiciales de los mensajes electrónicos masivos no solicitados recibidos en las casillas electrónicas de los órganos de la administración del estado y de sus funcionarios.
<https://www.bcn.cl/leychile/navegar?idNorma=251713>
- D.S. N°1/2015, aprueba norma técnica sobre sistemas y sitios web de los órganos de la administración del Estado.
<https://www.bcn.cl/leychile/navegar?idNorma=1078308>
- D.S N°5996/1999, Crea Red Interna (INTRANET) del Estado y entrega su implementación, puesta en marcha, administración, coordinación y supervisión al Ministerio del Interior y Seguridad Pública.
<https://www.bcn.cl/leychile/navegar?idNorma=147449&idParte=>
- D.S. N°1.299/2004, establece nuevas normas que regulan la Red de Conectividad del Estado.
<https://www.bcn.cl/leychile/navegar?idNorma=237437&idParte=>
- D.S. N°14/2014, Modifica decreto n°181, de 2002, que aprueba reglamento de la ley 19.799 sobre documentos electrónicos, firma electrónica y la certificación de dicha firma, y deroga los decretos que indica.
<https://www.bcn.cl/leychile/navegar?idNorma=1059778>
- DECRETO 142/2005, que establece el reglamento sobre interceptación y grabación de comunicaciones telefónicas y de otras formas de telecomunicación.
<https://www.bcn.cl/leychile/navegar?idNorma=242261>

Normas sectoriales de Ciberseguridad específicas de otras Instituciones.

- SUBTEL
 - Aprueba norma técnica sobre fundamentos generales de ciberseguridad para el diseño, instalación y operación de redes y sistemas utilizados para la prestación de servicios de telecomunicaciones.
https://www.subtel.gob.cl/wp-content/uploads/2020/08/ResEx1318_Aprueba_Norma_Tecnica_Ciberseguridad.pdf
- CMF
 - Ran 20-10 gestión de seguridad de la información y Ciberseguridad.
https://www.cmfchile.cl/portal/principal/613/articles-29310_doc_pdf.pdf
 - Ran 20-8 información de incidentes operacionales
https://www.cmfchile.cl/portal/principal/613/articles-28983_doc_pdf.pdf
- SUSESO
 - Gestión de la seguridad de la información modifica el título i. gobierno corporativo e incorpora el título v. gestión de la seguridad de la información, ambos del libro vii. aspectos operacionales y administrativos, y modifica el título ii. gestión de reportes e información para la supervisión (gris), del libro ix. sistemas de información. informes y reportes, del compendio de normas del seguro social de accidentes del trabajo y enfermedades profesionales de la ley n°16.744.
<https://www.suseso.cl/612/w3-article-622064.html>

Normas Chilenas ISO vigentes al 2021 disponibles en el Instituto Nacional de Normalización (INN):

NCh-ISO27799:2018	Informática de la salud - Gestión de la seguridad de la información relativa a la salud usando la norma ISO/IEC 27002.
NCh-ISO27036/3:2015	Tecnología de la información - Técnicas de seguridad - Seguridad de la información para las relaciones con proveedores - Parte 3: Directrices para la seguridad en la cadena de suministro de las tecnologías de la información y la comunicación.
NCh-ISO27040:2015	Tecnología de la información - Técnicas de seguridad - Seguridad de almacenamiento.
NCh-ISO27032:2015	Tecnología de la información - Técnicas de seguridad - Directrices para la ciberprotección.
NCh-ISO27037:2015	Tecnología de la información - Técnicas de seguridad - Directrices para la identificación, recopilación, adquisición y preservación de evidencia digital.
NCh-ISO27031:2015	Tecnologías de la información - Técnicas de seguridad - Directrices para la preparación de las tecnologías de la informática y comunicaciones para la continuidad del negocio.
NCh-ISO27036/2:2015	Tecnología de la información - Técnicas de seguridad - Seguridad de la información para las relaciones con proveedores - Parte 2: Requisitos.
NCh-ISO27036/1:2015	Tecnología de la información - Técnicas de seguridad - Seguridad de la información en las relaciones con los proveedores - Parte 1: Visión general y conceptos.
NCh-ISO27014:2015	Tecnología de la información - Técnicas de seguridad - Gobernanza de seguridad de la información.
NCh-ISO27002:2013	Tecnologías de la información - Técnicas de seguridad - Código de prácticas para los controles de seguridad de la información.
NCh-ISO IEC 27005:2020	Tecnología de la información - Técnicas de seguridad - Gestión del riesgo de seguridad de la información.

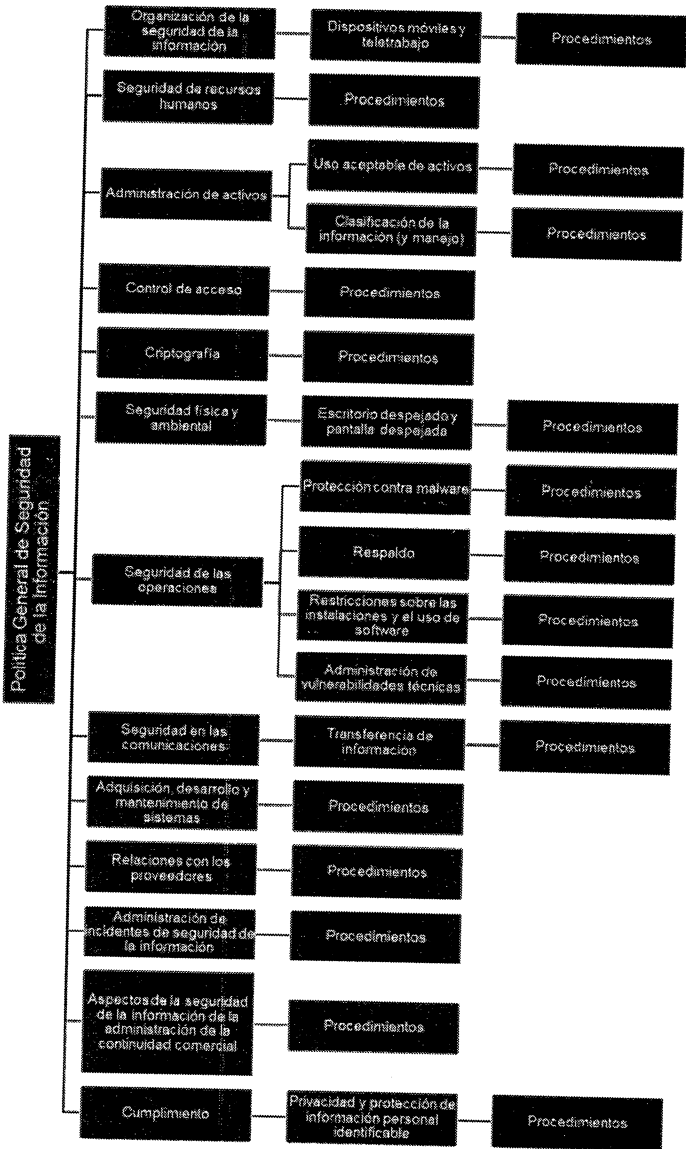
NCh-ISO 27001:2020	IEC	Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de la seguridad de la información – Requisitos.
NCh-ISO 27007:2020	IEC	Seguridad de la información, ciberseguridad y protección de la privacidad - Directrices para la auditoría de sistemas de gestión de seguridad de la información.
NCh-ISO 27013:2020	IEC	Tecnología de la información - Técnicas de seguridad - Orientación sobre la implementación integrada de ISO/IEC 27001 e ISO/IEC 20000-1.
NCh-ISO 27102:2020	IEC	Gestión de la seguridad de la información - Directrices para el seguro cibernético.
NCh-ISO 27701:2020	IEC	Técnicas de seguridad - Extensión de ISO/IEC 27001 e ISO/IEC 27002 para la gestión de la información de privacidad - Requisitos y directrices.
NCh-ISO 27003:2019	IEC	Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de seguridad de la información – Orientación.
NCh-ISO 27018:2019	IEC	Tecnología de la información - Técnicas de seguridad - Código de prácticas para la protección de la información de identificación personal (PII) en nubes públicas que desempeñen el rol de procesadores de PII.
NCh-ISO 27035/2:2019	IEC	Tecnología de la información - Técnicas de seguridad - Gestión de incidentes de seguridad de la información - Parte 2: Directrices para planificar y preparar para la respuesta a incidentes.
NCh-ISO 27042:2019	IEC	Tecnología de la información - Técnicas de seguridad - Directrices para el análisis e interpretación de evidencia digital.
NCh-ISO 27033/1:2019	IEC	Tecnología de la Información - Técnicas de seguridad - Seguridad de red - Parte 1: Descripción general y conceptos.
NCh-ISO 27010:2019	IEC	Tecnología de la información - Técnicas de seguridad - Gestión de la seguridad de la información para comunicaciones intersectoriales e interorganizacionales.
NCh-ISO 27019:2019	IEC	Tecnología de la información - Técnicas de seguridad - Controles de la seguridad de la información para la industria de servicios energéticos.
NCh-ISO 27043:2018	IEC	Tecnología de la información - Técnicas de seguridad - Principios y procesos de investigación de incidentes.
NCh-ISO 27021:2018	IEC	Tecnología de la información - Técnicas de seguridad - Requisitos de competencia para profesionales de sistemas de gestión de seguridad de la información.
NCh-ISO 27035/1:2018	IEC	Tecnología de la información - Técnicas de seguridad - Gestión de incidentes de seguridad de la información - Parte 1: Principios de gestión de incidentes.
NCh-ISO 27011:2018	IEC	Tecnología de la información - Técnicas de seguridad - Código de prácticas para controles de seguridad de la información basados en ISO IEC 27002 para organizaciones de telecomunicaciones.
NCh-ISO 27039:2018	IEC	Tecnología de la información - Técnicas de seguridad - Selección, despliegue y operación de sistemas de detección y prevención de intrusión (IDPS).
NCh-ISO 27000:2018	IEC	Tecnología de la información - Técnicas de seguridad - Sistemas de Gestión de la Seguridad de la Información (SGSI) - Visión general y vocabulario.
NCh-ISO 27006:2016	IEC	Tecnología de la Información - Técnicas de Seguridad - Requisitos para los organismos que realizan auditorías y certificación de sistemas de gestión de seguridad de la información.
NCh-ISO 27017:2016	IEC	Tecnología informática - Técnicas de seguridad - Código de práctica para los controles de seguridad de la información basado en ISO/IEC 27002

10.- ANEXO 2: DOCUMENTOS Y RECURSOS DE REFERENCIA

- Políticas de Seguridad de Minsal:
 - <http://isalud.minsal.cl/ministerio/dgstic/SGSI/Paginas/default.aspx>

- Páginas de gobierno:
 - <https://www.ciberseguridad.gob.cl/>
 - <https://www.csirt.gob.cl/>
 - <https://www.csirt.gob.cl/sistemas-y-herramientas/>
- Controles de Seguridad del NIST: SP 800-53 Controls and SP 800-53B Control Baselines Resources for Implementers:
 - <https://csrc.nist.gov/Projects/risk-management/sp800-53-controls>
- Políticas tipo y guías de Seguridad de Incibe:
 - <https://www.incibe.es/>
- Recursos de Seguridad de la Información:
 - <https://www.iso27000.es/iso27002.html>
- Instructivo Presidencial N°8 :
 - <https://www.ciberseguridad.gob.cl/media/2018/10/Instructivo-008-23.10.2018-Ciberseguridad.pdf>

11.- ANEXO 3: EJEMPLO DE ESTRUCTURA DE POLÍTICAS Y PROCEDIMIENTOS



2° PUBLIQUESE, el contenido del archivo computacional correspondiente, en conjunto con la presente resolución, por el Departamento de Tecnologías de la Información y las Comunicaciones, en la página web del Ministerio de Salud, https://www.minsal.cl/seguridad_de_la_informacion/, y en el Banner de transparencia del Ministerio de Salud.

3° REMÍTASE, a los funcionarios que corresponda un ejemplar del instructivo, vía correo electrónico.

ANÓTESE Y COMUNÍQUESE



DR. ENRIQUE PARÍS MANCILLA
MINISTRO DE SALUD

DISTRIBUCIÓN:

- Gabinete Ministro de Salud
- Gabinete Subsecretaría de Salud Pública
- Gabinete Subsecretaría de Redes Asistenciales
- Departamento de Tecnologías de la Información y Comunicaciones
- Departamento de Salud Digital.
- Archivo División Jurídica
- Archivo.